



Threat Modelling of LLM-Integrated Systems

A Comparative Analysis of Classical and AI-Assisted Threat Modelling Approaches

Ananth Chowdary Ramineni
Vamshi Krishna Burri

This thesis is submitted to the Faculty of Computing at Blekinge Institute of Technology in partial fulfillment of the requirements for the degree of Master of Science in Software Engineering. The thesis is equivalent to 20 weeks of full-time studies.

The authors declare that they are the sole authors of this thesis and that they have not used any sources other than those listed in the bibliography and identified as references. They further declare that they have not submitted this thesis at any other institution to obtain a degree.

Contact Information:

Authors:

Ananth Chowdary Ramineni
E-mail: anrb24@student.bth.se

Vamshi Krishna Burri
E-mail: vabr24@student.bth.se

University Advisor:

Dr. Oleksandr Adamov
Senior Lecturer, Department of Software Engineering
Blekinge Institute of Technology

Faculty of Computing
Blekinge Institute of Technology
SE-371 79 Karlskrona, Sweden

Internet : www.bth.se
Phone : +46 455 38 50 00
Fax : +46 455 38 50 57

Abstract

Background. The integration of large language models (LLMs) into software systems introduces new interactions among users, application components, data stores, and LLM components, creating security concerns that require systematic threat modelling. Classical approaches provide structured, architecture-oriented analysis, while AI-based approaches may provide additional contextual reasoning for identifying security threats.

Objectives. This thesis compares five threat modelling approaches for LLM-integrated software systems: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA.

Methods. A comparative empirical study was conducted using three predefined LLM-integrated system scenarios. Waibloz AB experts analysed the scenario architectures and established an expert-vetted reference threat set containing 98 threats: 32 for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. Generated findings were mapped to the reference threats using predefined semantic matching criteria, with primary true positives, duplicates, false positives, and false negatives distinguished during the evaluation. The primary quantitative analysis considers Precision, Recall, and F1-score. Supporting analyses examine threat categorization, redundancy, LLM-specific threat coverage, consistency across repeated runs, and observed processing errors. Evidence grounding was assessed separately for all 1,025 generated findings against the architectural evidence of the corresponding scenarios using a predefined grounding rubric. Qualitative practitioner feedback was obtained with help from Rickard Erwinson of Waibloz AB.

Results. The five approaches produced 1,025 raw threat findings across the three scenarios. ThreMoLIA generated 328 findings, Microsoft TMT 301, GPT-5.6 181, OWASP Threat Dragon 123, and Llama 3 8B executed through Ollama 92. GPT-5.6 achieved the highest Precision (47.71%), while ThreMoLIA achieved the highest Recall (70.41%). ThreMoLIA also achieved the highest F1-score (52.67%), followed by GPT-5.6 (50.24%) and Llama 3 8B (24.39%). The results further showed substantial differences in false positives, false negatives, and redundant findings across the approaches. The evidence-grounding assessment classified 329 findings (32.10%) as Fully Grounded, 689 (67.22%) as Partially Grounded, and 7 (0.68%) as Not Grounded, with GPT-5.6 achieving the highest full grounding rate (74.59%). A supplementary feature-completeness analysis was conducted to characterize documented capabilities of the evaluated approaches. Qualitative practitioner feedback was used to provide additional industry context.

Conclusions. The results indicate that raw finding volume alone is insufficient for comparing threat modelling approaches. The evaluated classical and AI-based approaches exhibited different strengths in threat coverage, precision, redundancy, and architectural evidence support. Within the scope of the three evaluated scenarios, the findings suggest that AI-based threat modelling can serve as a complementary component of a human-supervised security analysis process rather than as a replacement for established threat modelling practices.

Keywords: threat modelling, large language models, cybersecurity, AI-based threat modelling, LLM-integrated systems

Data Availability Statement

The research data and supporting materials generated and analysed during this thesis are maintained in a version-controlled project repository to support transparency and reproducibility. The publicly available research artifacts include only materials approved for repository sharing. Where permitted, these artifacts include the three system scenarios and their architectures, threat modelling outputs, the expert-vetted reference threat set, threat classification and mapping criteria, evaluation guidelines, AI prompts, model and tool configurations, and processed evaluation data.

The approved artifacts support traceability between the experimental inputs, generated outputs, evaluation data, and reported results for OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. Confidential, proprietary, personal, or otherwise restricted materials, including non-approved Waibloz AB materials, are excluded from the publicly available repository. Practitioner feedback from Rickard Erwinson of Waibloz AB is reported only where appropriate and approved for inclusion.

The repository is available at: <https://github.com/ANANTH2523/Master-Thesis->

Acknowledgments

We would like to express our sincere gratitude to everyone who supported and contributed to the completion of this master's thesis.

First and foremost, we would like to express our deepest appreciation to our academic supervisor, **Dr. Oleksandr Adamov, Senior Lecturer at the Department of Software Engineering, Blekinge Institute of Technology**, for his continuous guidance, valuable feedback, and constructive discussions throughout this research project. His expertise and support were instrumental in shaping the research methodology and improving the quality of this work throughout the different stages of the thesis.

We would also like to extend our sincere thanks to **Rickard Erwinson of Waibloz AB** for providing valuable practitioner perspectives and practical feedback on the threat modelling outputs evaluated in this study. His feedback provided useful industry context for interpreting the results and considering the practical implications of the evaluated approaches.

We are grateful to **Blekinge Institute of Technology** for providing the academic environment, resources, and opportunities that enabled us to conduct this research in the fields of Software Engineering and Security.

Finally, we would like to thank our families, friends, and everyone who supported us throughout our master's studies. Their encouragement, patience, and motivation have been invaluable throughout this journey.

Ananth Chowdary Ramineni

Vamshi Krishna Burri

Contents

Abstract	i
Data Availability Statement	iii
Acknowledgments	v
1 Introduction	1
1.1 Background	2
1.2 Problem Statement	2
1.3 Scope of the Thesis	4
1.4 Research Objectives	5
1.5 Research Questions	6
1.6 Contribution of the Thesis	8
1.7 Thesis Structure	9
2 Related Work	11
2.1 Traditional Threat Modelling	11
2.2 Threat Modelling for AI and LLM-Integrated Systems	12
2.3 LLM-Based and LLM-Assisted Threat Modelling	12
2.4 Comparative Evaluation of Threat Modelling Approaches	13
2.5 Research Gap	20
2.6 Summary and Relation to the Present Study	21
3 Method	23
3.1 Research Questions	23
3.1.1 Threat Coverage	23
3.1.2 Threat Precision	24
3.1.3 Evidence Grounding	24
3.2 Research Design	25
3.3 Research Methodology	28
3.4 Study Object Selection	29
3.5 Evaluated Approaches	31
3.6 Experimental Setup	33
3.7 Threat Normalization and Classification	34
3.8 Evaluation Criteria	37
3.8.1 Threat Coverage	37
3.8.2 Precision	38
3.8.3 Evidence Grounding	39

3.8.4	Supporting Evaluation Analyses	40
3.9	Data Collection and Management	41
3.10	Validity and Reliability of the Approach	43
3.10.1	Construct Validity	43
3.10.2	Internal Validity	43
3.10.3	External Validity	44
3.10.4	Reliability	44
3.10.5	Methodological Limitations	45
3.11	Practical Relevance and Practitioner Perspective	47
3.11.1	Practitioner Feedback Design	47
3.11.2	Role and Limitations of Practitioner Feedback	48
3.11.3	Generative AI Use and Experimental Configuration	48
4	Results and Analysis	49
4.1	Overview of Results	49
4.2	Dataset Overview	50
4.3	Threat Normalization Results	50
4.4	Reference Threat Coverage Analysis	51
4.5	Threat Precision Analysis	51
4.6	STRIDE Category Analysis	53
4.7	LLM-Specific Security Analysis	54
4.8	LLM Run Consistency Analysis	55
4.9	Error Analysis	56
4.10	Summary of Results	57
4.11	Exploratory Qualitative Industry Feedback	58
5	Discussion	59
5.1	Research Questions Revisited	59
5.2	Classical Tools Compared with LLM-Based Approaches	60
5.3	Interpretation of Threat Generation Results	61
5.4	Discussion of RQ1: Threat Coverage	62
5.5	Discussion of RQ2: Threat Precision	62
5.6	Discussion of RQ3: Evidence Grounding	63
5.7	Reliability and Validity Considerations	64
5.8	Practical Implications	65
5.9	Ethical and Societal Considerations	66
5.10	Discussion Summary	67
5.11	Implications for Security Practitioners	67
5.11.1	Feature Completeness	68
6	Conclusions and Future Work	69
6.1	Conclusions	69
6.1.1	Conclusion for RQ1: Threat Coverage	69
6.1.2	Conclusion for RQ2: Threat Precision	70
6.1.3	Conclusion for RQ3: Evidence Grounding	70
6.1.4	Overall Conclusion	71
6.2	Contribution of the Thesis	73

6.2.1	A Multidimensional Empirical Evaluation Framework	73
6.2.2	Empirical Characterization of Coverage, Precision, and Redundancy	73
6.2.3	Evidence Grounding as a Distinct Methodological Dimension .	74
6.3	Placing the Thesis in Perspective	74
6.4	Limitations	75
6.5	Future Work	76
6.6	Final Remarks	77
References		79
A Supplemental Information		83
A.1	Evaluated System Scenarios	83
A.1.1	Scenario 1: LLM-Integrated Authentication System	83
A.1.2	Scenario 2: LLM-Integrated Secure File Management System .	84
A.1.3	Scenario 3: LLM-Integrated Account Recovery and Profile Management System	84
A.2	Expert Reference Threat Set	84
A.3	Threat Mapping Methodology	85
A.4	Detailed Evaluation Tables	87
A.5	Generated Threat Model Outputs	87
A.6	Additional Evaluation Calculations	88
A.6.1	Threat Coverage	88
A.6.2	Threat Recall	88
A.6.3	Threat Precision	88
A.6.4	F1-Score	89
A.7	Repository Structure	89
A.8	Limitations and Additional Notes	90
A.9	LLM Experimental Configuration and Prompts	90
A.9.1	ChatGPT Configuration	91
A.9.2	Ollama Configuration	91
A.9.3	Common Experimental Prompts for GPT-5.6 and Llama 3 8B via Ollama	91

The rapid adoption of large language models (LLMs) has enabled software systems to incorporate natural-language interaction, contextual processing, and model-generated responses. Their integration introduces additional interactions among users, application components, data stores, external services, and LLM components, creating security considerations that may not be fully captured by conventional software security analysis [5, 10, 26].

Threat modelling is an established security engineering practice for identifying and analysing potential security threats during software design and development. Traditional approaches examine system architectures, components, data flows, and trust relationships using structured methods such as STRIDE [17, 25]. Empirical studies have evaluated the effectiveness of such approaches, while automated tools can support threat identification using structured system models and predefined security knowledge [7, 17].

LLM-integrated systems introduce additional security considerations because natural-language inputs, contextual information, model behaviour, and application functionality interact during system operation. Concerns such as prompt injection and information disclosure have consequently received increasing attention [5, 8, 26]. These concerns complement conventional application-level threats and motivate analysis that considers both the surrounding architecture and the characteristics of LLM integration [10, 13].

Recent research has also investigated LLMs as tools for security analysis and threat elicitation. Approaches have explored combining LLMs with established threat modelling methodologies, retrieval mechanisms, and structured security knowledge [9, 10, 15, 24]. However, generated threat sets may vary with the model, prompt, system representation, and execution conditions, raising questions concerning their coverage, precision, consistency, and practical usefulness [16, 24].

This thesis investigates these differences through a comparative empirical study of five threat modelling approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. The approaches are applied to the same three predefined LLM-integrated software system scenarios. The primary evaluation considers reference-threat coverage and precision, while evidence grounding is examined as an additional analytical dimension. Supporting analyses examine threat categorization, redundancy, LLM-specific threat coverage, and consistency across repeated runs.

1.1 Background

Threat modelling provides a structured means of identifying potential security threats from a system’s architecture and security properties. STRIDE-based approaches categorize threats as Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. Empirical research has examined the correctness and completeness of such threat identification, while automated tools provide mechanisms for representing system architectures and generating security-relevant findings [7, 17, 21].

The integration of LLMs changes the security context in which these methods are applied. LLM-integrated applications can combine conventional software components with natural-language inputs, contextual data, model-generated responses, and external services. Security concerns may therefore arise from both conventional application behaviour and interactions involving the LLM component, including prompt injection and information disclosure [8, 10, 13].

LLMs have consequently been investigated as tools for threat modelling and security analysis. Recent approaches include LLM-assisted threat modelling and framework-based security analysis, while comparative studies have begun to evaluate the quality and variability of LLM-generated threat findings [10, 15, 24]. These studies motivate evaluation procedures that distinguish the number of generated findings from their correspondence to relevant security threats.

This thesis evaluates three LLM-integrated system scenarios using five approaches. Waibloz AB security experts analysed the scenario architectures and independently identified the reference threats used to establish an expert-vetted reference threat set containing 98 threats: 32 for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. The reference threat set provides the comparison baseline for evaluating reference-threat coverage and is treated as an expert-vetted comparison baseline rather than as an exhaustive or absolute ground-truth representation.

Generated findings are retained as the primary experimental data. Where required, a secondary normalization analysis groups semantically equivalent or overlapping findings to examine redundancy and semantic overlap. Normalization does not replace the original generated findings or the primary evaluation dataset.

1.2 Problem Statement

The increasing use of large language models (LLMs) within software systems creates a need to evaluate whether existing threat modelling practices adequately capture the security risks introduced by these systems. Traditional threat modelling approaches provide structured mechanisms for analysing software architectures, while LLM-integrated applications introduce additional interactions involving LLM components, prompts, contextual information, external content, and generated responses [8, 10, 13].

At the same time, LLM-based approaches provide an alternative mechanism for threat identification by interpreting system descriptions and reasoning about potential security risks. Recent research has investigated LLM-based and LLM-assisted approaches for threat elicitation and threat modelling [9, 10, 15, 24]. However, the characteristics of their generated threat sets may differ from those produced by es-

established threat modelling approaches. Generated findings may contain redundant findings, false positives, or findings with limited architectural evidence support, and results may vary according to the model, prompt, system representation, and execution conditions [16, 24]. Consequently, the number of generated findings alone is not an adequate measure of threat modelling effectiveness. Empirical studies of threat modelling have likewise treated correctness, completeness, and false-positive findings as distinct evaluation characteristics [17, 20].

The problem addressed by this thesis is therefore the need for a systematic comparison of classical threat modelling approaches and multiple LLM-based approaches when analysing the same LLM-integrated software systems. In particular, there is a need to determine how the approaches differ in their ability to identify threats represented in an expert-vetted reference threat set, the precision of their generated findings, and the extent to which identified threats can be supported by evidence from the analysed system architectures. Supporting analyses further examine normalization, redundancy, STRIDE classification, LLM-specific security risks, and consistency across repeated LLM executions. The importance of considering architectural representation and the relationship between identified threats and system information has also been examined in previous threat modelling research [18, 19, 25].

To address this problem, this thesis conducts a comparative empirical study of five threat modelling approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. The approaches are evaluated using the same three predefined LLM-integrated software system scenarios. Their generated findings are collected and preserved as the primary experimental data and subsequently analysed using predefined evaluation criteria.

An expert-vetted reference threat set containing 98 threats across the three scenarios is used as the comparison baseline for the reference-threat coverage analysis. The baseline contains 32 reference threats for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. The reference threat set provides a consistent expert-vetted comparison baseline and is not treated as an exhaustive or absolute ground-truth representation. This distinction is important because reference- or expert-based threat sets do not necessarily provide a complete representation of all possible vulnerabilities or security conditions, and vulnerability-grounded validation has been proposed as a complementary means of validating threat modelling results [1].

The study distinguishes between the original generated findings and normalized threat groups. The original findings constitute the primary experimental output because they preserve the actual behaviour and output volume of each approach. Normalization is used as a secondary analytical step to identify semantically equivalent or overlapping findings and to support meaningful comparison without discarding the original observations. The need to account for differences in threat representations when comparing automated threat modelling approaches has also been considered in comparative research [7, 24].

Evidence grounding is analysed as a separate analytical dimension from reference-threat matching. Each generated finding is assessed against the architectural evidence of its corresponding scenario using a predefined grounding rubric that distinguishes Fully Grounded, Partially Grounded, Not Grounded, and Unassessable findings. Full grounding requires both an identifiable architectural association and sufficient support for the claimed attack mechanism and security consequence. This

distinction allows architectural support to be examined independently of whether a finding corresponds to a threat in the expert-vetted reference threat set.

The resulting comparison is intended to provide empirical evidence about the characteristics of classical and LLM-based threat modelling approaches under the experimental conditions of this study, rather than to establish that one approach universally replaces the others.

1.3 Scope of the Thesis

This thesis focuses on the comparative evaluation of threat modelling approaches applied to LLM-integrated software systems. The study considers five threat modelling approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. OWASP Threat Dragon and Microsoft Threat Modeling Tool represent classical, architecture-oriented threat modelling approaches, while GPT-5.6 and Llama 3 8B represent general-purpose LLM-based approaches and ThreMoLIA represents an LLM-assisted threat modelling approach.

The evaluation is conducted using three predefined LLM-integrated software system scenarios. The scenarios provide system architectures and functional and security information that are used as the basis for threat identification. The same underlying scenario definitions are used across the evaluated approaches to support a consistent comparison of their outputs, while the representation and interaction method may differ according to the requirements of each approach.

The primary experimental unit is the set of threats generated by each approach for a given scenario. The analysis considers the original findings produced by the approaches, including their threat descriptions and available security classifications. These original findings are retained as the primary experimental data. For ThreMoLIA, the complete raw output is retained in this form. Where applicable, semantic normalization is performed as a secondary analytical step to identify overlapping or semantically equivalent findings; normalization does not replace or alter the original generated findings.

The primary comparison focuses on reference-threat coverage and threat precision, while evidence grounding is examined as an additional analytical dimension. Reference-threat coverage evaluates the extent to which generated findings correspond to the predefined reference threat set. Threat precision evaluates the proportion of generated findings classified as primary true positives according to the defined evaluation criteria. False positives and false negatives are retained explicitly in the evaluation to distinguish incorrect generated findings from reference threats that were not identified.

Evidence grounding evaluates whether generated threats can be supported by concrete evidence from the corresponding system architecture and its specified components, data flows, trust boundaries, or security requirements. The importance of architectural representation and the relationship between threat analysis and system information has been investigated in studies of DFD-based and architecture-oriented security analysis [18, 19, 25].

Supporting analyses consider raw finding volume, threat normalization and re-

dundancy, STRIDE categorization, identification of LLM-specific security risks, and consistency across repeated LLM executions. These analyses are used to contextualize the primary evaluation rather than to replace the reference-threat coverage and precision measures.

The reference baseline consists of 98 threats across the three scenarios, with 32 reference threats for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. The reference threat set provides a structured comparison baseline and is not treated as an exhaustive representation of every possible security threat [1].

The scope of this thesis is limited to the threat modelling outputs generated for the defined scenarios. It does not attempt to establish the overall security of the implemented systems, measure the effectiveness of security controls after deployment, or determine whether any approach is universally superior for all software systems. Similarly, the study does not treat the number of generated threats as a standalone measure of threat modelling quality.

The thesis therefore evaluates the approaches based on their observed outputs under the defined experimental conditions. The findings and conclusions are limited to these conditions and are intended to provide empirical evidence for comparing classical and LLM-based threat modelling approaches for LLM-integrated systems.

1.4 Research Objectives

The objective of this thesis is to empirically compare classical and AI-based threat modelling approaches for LLM-integrated software systems. The specific objectives are:

- To define three predefined LLM-integrated software system scenarios suitable for comparative threat modelling evaluation.
- To generate and preserve threat modelling outputs from five evaluated approaches - OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA - under the defined experimental conditions.
- To quantify and compare reference-threat coverage of the evaluated approaches against the expert-vetted reference threat set across the three scenarios.
- To assess and compare the precision of the generated threat findings using the predefined threat classification and evaluation criteria, including primary true positives, false positives, false negatives, and duplicate findings.
- To quantitatively characterize the evidence grounding of generated threat findings in relation to concrete architectural evidence using a predefined per-finding grounding rubric.
- To analyse redundancy, semantic overlap, and normalization within the generated findings while retaining the original raw findings as the primary experimental outputs.

- To examine supporting characteristics of the generated threat sets, including STRIDE classification, identification of LLM-specific security threats, and consistency across repeated LLM executions.
- To use practitioner feedback from Waibloz AB to provide qualitative context for interpreting the results of the evaluated classical and AI-based approaches.

1.5 Research Questions

Based on the identified research problem and research objectives, this thesis addresses the following research questions:

1. **RQ1:** How does the threat coverage of AI-based threat modelling approaches compare with classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios?
2. **RQ2:** How does the precision of threat findings generated by AI-based approaches compare with that of classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios?
3. **RQ3:** How can the evidence grounding of threat findings generated by AI-based and classical threat modelling approaches be characterized with respect to the architectural evidence of the analysed system scenarios?

RQ1 Justification

Threat identification and coverage are central objectives of threat modelling. RQ1 therefore examines the extent to which the evaluated approaches identify threats represented in the expert-vetted reference threat set when applied to the same three structured LLM-integrated system scenarios [17, 20].

The comparison considers OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. Reference-threat coverage is evaluated against the expert-vetted reference baseline containing 98 threats: 32 threats for Scenario 1, 33 threats for Scenario 2, and 33 threats for Scenario 3. The reference baseline was independently derived from the defined scenario architectures by security experts from Waibloz AB and is used as a comparison reference rather than as an assumption of exhaustive or absolute ground truth.

The primary comparison retains the complete generated outputs of each approach. For example, the 328 findings generated by ThreMoLIA are retained as its primary experimental output, consisting of 106 findings for Scenario 1, 105 findings for Scenario 2, and 117 findings for Scenario 3. Where required, a secondary normalization analysis groups semantically equivalent or overlapping findings for comparison. Normalization does not replace or alter the original generated findings, and multiple findings mapped to the same reference threat do not increase reference-threat coverage.

RQ2 Justification

Threat generation volume alone does not indicate whether generated findings correspond to relevant threats in the evaluation baseline. RQ2 therefore examines the precision of the threat findings generated by the evaluated classical and AI-based approaches.

Generated findings are assessed according to their correspondence with the expert-vetted reference threat set and the predefined threat classification and evaluation criteria. The analysis distinguishes primary true positives, duplicate findings, false positives, and false negatives. A primary true positive is a generated finding that corresponds to a reference threat under the defined mapping criteria. Additional findings that correspond to an already matched reference threat are classified as duplicates and do not contribute additional reference-threat coverage. A false positive is a generated finding that does not correspond to a reference threat under the defined criteria. A false negative represents a reference threat that was not identified by the evaluated approach.

Precision is calculated from the resulting primary true-positive and false-positive classifications, while recall and F_1 -score are derived from the same reference-matching data. This allows differences in generated finding volume and redundancy to be interpreted without treating a larger number of generated findings as inherently better. Duplicate findings are retained in the raw output and analysed separately through the redundancy analysis rather than being counted as additional primary true positives.

RQ3 Justification

A generated security threat should be applicable to the specific system under analysis rather than representing only a generic or theoretically possible concern. RQ3 therefore examines how generated threat findings can be connected to evidence contained in the corresponding system architectures [18, 19, 25].

Evidence grounding considers whether a generated threat can be connected to concrete architectural evidence, including relevant system components, data flows, trust boundaries, assets, or specified security requirements. It also considers whether the claimed threat mechanism and security consequence are supported by the properties and relationships represented in the architecture. This distinction is particularly relevant for LLM-based approaches because natural-language generation may produce plausible security concerns that are not necessarily supported by the architectural information provided to the model [16, 24].

The study operationalizes this dimension by assessing each of the 1,025 generated findings against the architectural evidence of its corresponding scenario using a predefined grounding rubric. Findings are classified as *Fully Grounded*, *Partially Grounded*, *Not Grounded*, or *Unassessable*. A finding is *Fully Grounded* when a specific architectural element or relationship is identified and the claimed attack mechanism and security consequence are supported by the available evidence. It is *Partially Grounded* when an architectural association is established but the evidence is incomplete, ambiguous, or does not fully support the claimed mechanism or consequence. It is *Not Grounded* when no defensible architectural association can be

established or the finding depends on an element, functionality, or relationship absent from the specified architecture. *Unassessable* is used when the available source material is insufficient to determine grounding.

The primary quantitative measure for RQ3 is the *full grounding rate*, defined as the proportion of all generated findings classified as *Fully Grounded*. The assessment is independent of reference-threat matching, so architectural support is not inferred from primary true-positive, duplicate, or false-positive classification. The *Partially Grounded*, *Not Grounded*, and *Unassessable* categories are retained as complementary descriptive results.

Grounding is therefore distinct from reference-threat correspondence. A finding may be supported by architectural evidence without corresponding to a reference threat, while a finding corresponding to a reference threat requires separate assessment of the evidence supporting its specific formulation, attack mechanism, and security consequence. RQ3 thus provides an additional architectural-evidence dimension for characterizing generated threat findings rather than a substitute for reference-threat coverage or precision.

Supporting analyses, including consistency across LLM executions, STRIDE categorization, LLM-specific threat identification, redundancy, and error analysis, contextualize the primary findings but do not replace the reference-threat coverage, precision, or evidence-grounding evaluations.

1.6 Contribution of the Thesis

This thesis contributes to the empirical evaluation of AI-based threat modelling for LLM-integrated software systems through a comparative empirical study involving established classical threat modelling approaches. The study combines quantitative comparison against an expert-vetted reference threat set with quantitative analysis of architectural evidence grounding and qualitative practitioner feedback.

The main contributions are:

- A comparative empirical evaluation of five threat modelling approaches - OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA - using the same three predefined LLM-integrated software system scenarios.
- An empirical comparison of reference-threat coverage across classical and AI-based approaches using an expert-vetted reference threat set derived from the scenario architectures by experts from Waibloz AB. The reference set contains 98 threats across the three scenarios.
- An empirical comparison of threat precision using predefined classification and mapping criteria, explicitly distinguishing primary true positives, duplicate findings, false positives, and false negatives.
- A quantitative evidence-grounding assessment that characterizes the extent to which generated threat findings are supported by concrete architectural evidence. The assessment applies a predefined per-finding grounding rubric

that distinguishes Fully Grounded, Partially Grounded, Not Grounded, and Unassessable findings while keeping grounding separate from reference-threat matching.

- A threat normalization and mapping procedure for identifying semantically equivalent or overlapping findings while retaining the original generated findings as the primary experimental data.
- Supporting analyses of STRIDE classification, LLM-specific security threat identification, redundancy, and consistency across repeated LLM executions to provide additional context for interpreting the primary evaluation results.
- Qualitative practitioner insights from Rickard Erwinson at Waibloz AB to support the interpretation of the generated threat modelling outputs and their practical characteristics.

1.7 Thesis Structure

The remainder of this thesis is organized as follows.

Chapter 2 presents related research on traditional threat modelling, AI security, LLM security risks, and LLM-based threat analysis.

Chapter 3 describes the research methodology, experimental design, selected threat modelling approaches, system scenarios, data collection process, expert reference threat set, and evaluation criteria.

Chapter 4 presents the generated threat modelling outputs and the comparative evaluation of the selected approaches across the three scenarios. The chapter reports the primary evaluation of reference-threat coverage and precision, together with supporting analyses of normalization, STRIDE categorization, LLM-specific threat identification, redundancy, consistency, and observed errors. It also reports the quantitative evidence-grounding assessment based on the architectural evidence of the corresponding scenarios.

Chapter 5 discusses the findings in relation to the research questions, previous research, methodological considerations, threats to validity, and practical implications, including the practitioner perspective.

Chapter 6 concludes the thesis by summarizing the main findings, answering the research questions, discussing the contributions and limitations of the study, and presenting directions for future research.

This chapter reviews research relevant to threat modelling of software systems incorporating artificial intelligence (AI) and large language models (LLMs). The review covers traditional threat modelling, security considerations for AI- and LLM-integrated systems, LLM-based and LLM-assisted threat modelling, and comparative evaluation of threat modelling approaches. The chapter concludes by identifying the research gap addressed by this thesis.

2.1 Traditional Threat Modelling

Threat modelling is a systematic approach to identifying and analysing potential security threats in a software system based on its architecture, assets, components, interactions, and trust boundaries [17]. Data Flow Diagrams (DFDs) are used to represent processes, data stores, external entities, data flows, and trust boundaries, providing a structured basis for analysing security properties of a system architecture [18, 25].

STRIDE is an established methodology for software threat modelling. It categorizes threats into Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. This structured taxonomy provides a consistent vocabulary for identifying and classifying threats across architectural elements [17, 22].

Threat modelling can also be supported by automated tools that apply predefined threat patterns, rules, or analysis procedures to architectural representations. Such approaches can reduce aspects of manual analysis and provide consistent analysis for comparable system architectures [7, 23]. However, the effectiveness of rule-based and architecture-driven approaches depends on the information represented in the model and the threat knowledge available to the analysis process. This can become challenging when systems contain emerging technologies or security properties that are not directly captured by established modelling assumptions [7, 25].

These characteristics provide the classical foundation for the present study. OWASP Threat Dragon and Microsoft Threat Modeling Tool (TMT) are therefore evaluated as representatives of established classical threat modelling approaches and compared with LLM-based and LLM-assisted approaches applied to the same system scenarios.

2.2 Threat Modelling for AI and LLM-Integrated Systems

The integration of AI and machine-learning components into software systems introduces additional assets, data flows, dependencies, and security considerations that may not be fully represented by conventional software threat models [5,13]. Conventional approaches such as STRIDE remain relevant because many threats affecting ordinary software components also apply to AI-enabled systems. At the same time, the characteristics of AI components and their interactions with surrounding application components can introduce additional security concerns [13].

These considerations become particularly important for applications that incorporate LLMs. Such systems may process natural-language input, contextual information, system instructions, and model-generated output, while also interacting with application functionality and external services. Security risks can consequently arise from both conventional application components and the interaction between the LLM and its surrounding architecture [5,8,26].

LLM-specific security concerns discussed in the literature include prompt injection, sensitive information disclosure, insecure handling of model-generated output, excessive agency, and manipulation of model instructions [5,6,8]. Prompt injection is particularly relevant to architectural analysis because attacker-controlled instructions or content may enter an LLM-integrated system through user input or external sources and influence subsequent model processing [8]. The security implications therefore depend not only on the model itself but also on how information flows between users, application components, external content, and the LLM.

This creates a need for threat modelling approaches that can consider both conventional architectural threats and security concerns associated with LLM integration. The present study addresses this issue by applying all evaluated approaches to predefined LLM-integrated system scenarios, thereby providing a common basis for examining the threats identified by classical, LLM-based, and LLM-assisted approaches.

2.3 LLM-Based and LLM-Assisted Threat Modelling

Recent research has investigated the use of LLMs for threat elicitation and threat modelling. This represents a shift from using language models for general cybersecurity tasks towards applying them to the interpretation of system descriptions and the identification of potential security threats [9,10,15,24].

LLMs are potentially applicable to threat modelling because the activity involves interpreting system descriptions, identifying assets and architectural elements, considering data flows and trust boundaries, and analysing possible attacker behaviour [10,24]. Compared with approaches based primarily on predefined rules and threat patterns, LLMs can process natural-language descriptions and contextual relationships across multiple system elements when generating potential threats [10,24].

An important distinction exists between general-purpose LLM-based threat elicitation and approaches that integrate LLMs with an explicit threat modelling methodology. ThreMoLIA, for example, investigates threat modelling of LLM-integrated

applications using a structured approach to architectural analysis and threat identification [9, 10]. Other emerging approaches apply LLMs to specific threat modelling or privacy modelling tasks, demonstrating that language models can support different stages and methodologies rather than constituting a single homogeneous threat modelling approach [15, 16].

The flexibility of LLM-based approaches also creates evaluation challenges. Generated threat sets may contain redundant or generic findings, may not be sufficiently grounded in the analysed architecture, and may vary according to the model, prompt, configuration, or execution conditions [16, 24]. Consequently, the number of threats generated by an approach is not by itself sufficient to establish the quality or completeness of the resulting threat model.

These issues motivate comparative empirical evaluation. Recent comparative research has begun to evaluate LLM-based threat elicitation approaches, but comparisons involving LLM-based, LLM-assisted, and classical approaches under common evaluation conditions remain an emerging area [24]. The present thesis therefore compares three AI-based approaches - GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA - with OWASP Threat Dragon and Microsoft TMT using the same three predefined LLM-integrated software system scenarios.

2.4 Comparative Evaluation of Threat Modelling Approaches

Existing research has evaluated threat modelling approaches using criteria such as threat coverage, correctness, false positives, architectural representation, automation, and characteristics of generated threat sets [7, 17, 20, 24]. These studies indicate that evaluating a threat modelling approach requires more than counting the number of generated threats. The validity of identified threats, their correspondence with the analysed architecture, and the criteria used to evaluate the findings are also important [17, 20].

A further methodological consideration concerns the use of reference threat sets as evaluation baselines. Reference sets provide a common basis for comparison, but they should not automatically be interpreted as exhaustive ground truth. Recent work has highlighted the difficulty of assessing threat model completeness using expert-produced reference models alone and has proposed vulnerability-grounded validation using applications with known vulnerabilities as a complementary evaluation mechanism [1]. This consideration is particularly relevant when evaluating generated threat sets, because a finding that is absent from a reference set may still represent a valid security concern.

The main strands of literature relevant to this thesis are synthesized in Table 2.1. The table emphasizes the focus of each work, its contribution to the research area, and its relevance to the present study.

Table 2.1: Synthesis of key related work and its relevance to the present study.

Work	Research Focus	Approach / Evidence	Key Contribution	Relevance and Remaining Gap
Scandariato et al. [17]	Classical threat modelling and STRIDE	Empirical evaluation of STRIDE, including valid threats, false positives, and false negatives.	Demonstrates that threat modelling effectiveness can be evaluated in terms of correctness and completeness rather than only the number of threats identified.	Provides a methodological foundation for evaluating reference-threat coverage, false positives, and false negatives. It does not evaluate LLM-based threat modelling.
Tuma and Scandariato [22]	Architectural threat analysis	Controlled comparison of two STRIDE-based architectural threat analysis techniques.	Shows that the scope and procedure used for architectural analysis can affect threat identification and analysis outcomes.	Supports the use of structured architectural representations when comparing threat modelling approaches. It does not address LLM-based threat elicitation.
Van Landuyt and Joosen [25]	Assumptions in STRIDE threat modelling	Descriptive study of assumptions made across STRIDE threat models.	Shows that assumptions can play different roles in threat modelling and that DFDs alone may not capture all relevant security context.	Motivates explicit attention to architectural context and assumptions when evaluating generated threat findings. The present study extends this concern to LLM-integrated architectures.

Continued on next page

Table 2.1 – continued from previous page

Work	Research Focus	Approach / Evidence	Key Contribution	Relevance and Remaining Gap
Schneider et al. [18]	Data Flow Diagrams and security analysis	Empirical experiment examining the influence of DFD representations on software security analysis.	Provides empirical evidence that the representation and information available in a system model can influence security analysis outcomes.	Supports the use of structured architectural scenarios as a common input condition for the comparative evaluation.
Granata and Rak [7]	Automated threat modelling	Systematic review and comparison of automated threat modelling techniques and open-source tools.	Shows the diversity of automated threat modelling approaches and differences in their modelling and automation capabilities.	Provides context for evaluating established automated/classical tools and motivates systematic comparison with newer LLM-based approaches.
Tuma et al. [23]	Automated security design flaw detection	Empirical comparison of automated model-query analysis with manual inspection.	Finds that complete automation is difficult, while some classes of security design flaws are more amenable to automated analysis.	Supports a cautious view of automation and motivates evaluation based on finding quality rather than assuming that automation alone improves security analysis.
Sion et al. [19]	Architectural context and threat applicability	Solution-aware DFDs incorporating security solutions into threat elicitation.	Shows that additional architectural and solution context can help reduce enumeration of non-applicable threats.	Directly motivates attention to applicability and false positives when comparing threat modelling outputs.

Continued on next page

Table 2.1 – continued from previous page

Work	Research Focus	Approach / Evidence	Key Contribution	Relevance and Remaining Gap
Mauri and Damiani [13]	Threat modelling of AI/ML systems	STRIDE-based methodology adapted to AI/ML assets and lifecycle stages.	Demonstrates that AI/ML systems introduce security characteristics requiring consideration beyond conventional IT-system threat modelling.	Provides a bridge between classical threat modelling and AI-enabled systems. It does not provide a controlled comparison of LLM-based and classical approaches.
Greshake et al. [8]	Security of LLM-integrated applications	Analysis and practical demonstration of indirect prompt injection attacks against LLM-integrated applications.	Demonstrates that external or retrieved content can influence LLM behaviour and introduce new attack vectors.	Establishes the security context motivating LLM-integrated scenarios. It focuses on application security rather than comparative threat modelling.
Agarwal et al. [2]	Prompt leakage in multi-turn LLM applications	Empirical investigation of prompt leakage and mitigation strategies.	Examines security risks associated with leakage of prompt information during multi-turn LLM interactions.	Supports consideration of LLM-specific security concerns. It does not evaluate threat modelling approaches against a common reference baseline.
Chen et al. [4]	Prompt injection mitigation	Structured-query defence separating instructions from untrusted data.	Demonstrates the importance of distinguishing trusted instructions from potentially untrusted input in LLM processing.	Provides security context for architectural threats in LLM-integrated systems. The work concerns defence rather than threat modelling evaluation.

Continued on next page

Table 2.1 – continued from previous page

Work	Research Focus	Approach / Evidence	Key Contribution	Relevance and Remaining Gap
Kaya et al. [12]	Prompt injection in third-party AI plugins	Security analysis of LLM-enabled web and plugin interactions.	Investigates prompt injection risks arising when LLM systems interact with third-party web content and services.	Strengthens the motivation for considering trust boundaries and external interactions in LLM-integrated architectures.
Chang et al. [3]	Indirect prompt injection in retrieved content	Study of indirect prompt injection in LLM systems using externally retrieved content.	Shows how malicious instructions can enter LLM contexts through retrieval mechanisms rather than direct user input.	Provides evidence for considering retrieval and external-data pathways in LLM-integrated architectures. It does not compare threat modelling methods.
Karanjai et al. [11]	Context contamination in LLM security analysis	Evaluation of passive prompt injection through network security logs.	Demonstrates that untrusted content incorporated into LLM context can influence security-related analysis.	Highlights the importance of data provenance and trust boundaries. It does not provide a comparative threat modelling evaluation.
Jedrzejewski et al. [10]	LLM-assisted threat modelling for LLM-integrated applications	Development of ThreMoLIA using LLMs, RAG, threat models, and architectural information.	Introduces a dedicated LLM-assisted threat modelling approach targeting LLM-integrated applications.	Provides the direct research basis for including ThreMoLIA in the present comparison. The present study evaluates it alongside classical tools and general-purpose LLMs under common scenarios.

Continued on next page

Table 2.1 – continued from previous page

Work	Research Focus	Approach / Evidence	Key Contribution	Relevance and Remaining Gap
Mollaeefar et al. [15]	LLM-assisted privacy threat modelling	PILLAR applies LLMs within the LINDDUN privacy threat modelling framework.	Demonstrates the application of LLMs to methodology-guided privacy threat analysis.	Supports the broader feasibility of LLM-assisted modelling while leaving open the question of comparative performance against classical approaches.
Van Landuyt et al. [24]	LLM-based threat elicitation	Comparative benchmark study of LLM-based threat elicitation tools.	Provides empirical evidence that LLM-based threat elicitation approaches can produce different threat-output profiles and highlights the need for systematic evaluation.	Closely related to the present study. This thesis additionally compares LLM-based, LLM-assisted, and classical approaches on common structured LLM-integrated scenarios using a common expert-vetted reference baseline.
Mbaka and Tuma [14]	LLM support for threat validation	Controlled empirical study of graphical models and LLM-generated information for threat validation.	Investigates how analysts use architectural models and LLM-generated information when validating identified threats.	Supports the importance of architectural evidence and human interpretation in threat validation. The present study focuses on generated threat findings and their correspondence with a common reference baseline.

Continued on next page

Table 2.1 – continued from previous page

Work	Research Focus	Approach / Evidence	Key Contribution	Relevance and Remaining Gap
Adamov et al. [1]	Validation of threat modelling results	Vulnerability-grounded validation of threat modelling results.	Investigates complementary validation of threat modelling results using vulnerable test applications.	Supports treating the expert-vetted reference set as a comparison baseline rather than absolute ground truth and motivates separate consideration of evidence grounding.

The literature therefore indicates that threat modelling approaches should be evaluated using multiple characteristics rather than a single measure. Empirical research on STRIDE has explicitly considered correctness, false-positive findings, and completeness [17], while research on automated threat modelling has demonstrated differences in modelling and automation capabilities across tools [7]. Research on LLM-based threat elicitation further indicates that generated threat sets require systematic evaluation and comparison [24].

The literature also indicates that the security analysis of AI- and LLM-integrated systems cannot necessarily be reduced to conventional application threats. Research has proposed adaptations of established threat modelling techniques for AI/ML systems [13], while work on LLM-integrated applications has identified security concerns such as indirect prompt injection [8]. LLM-assisted approaches such as ThreMoLIA further demonstrate the potential for integrating LLMs into structured threat modelling processes [10].

However, the reviewed literature provides comparatively limited evidence on the empirical comparison of established architecture-oriented threat modelling tools, general-purpose LLMs, and LLM-assisted threat modelling approaches when the same LLM-integrated system scenarios are used as input. Such comparisons also require explicit treatment of differences in threat representation, redundant findings, false positives, false negatives, and the relationship between generated findings and architectural evidence. These considerations are particularly important when an expert reference set is used as the comparison basis, because the absence of a generated finding from the reference set does not by itself establish that the underlying security concern is invalid [1].

This thesis addresses this gap through a comparative empirical evaluation of five approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. The approaches are evaluated using the same three predefined LLM-integrated software system scenarios. Generated findings are compared using an expert-vetted reference threat set and predefined threat-mapping criteria. The evaluation explicitly distinguishes primary true positives, duplicate findings, false positives, and false negatives and

uses precision, recall, and F_1 -score as quantitative measures. Supporting analyses examine normalization, redundancy, STRIDE categorization, LLM-specific threat identification, and other characteristics of the generated findings.

2.5 Research Gap

The reviewed literature demonstrates substantial research on classical threat modelling, security analysis of AI- and LLM-integrated systems, and the emerging use of LLMs for threat elicitation and threat modelling [7, 10, 17, 24]. However, the comparative behaviour of established threat modelling tools, general-purpose LLMs, and LLM-assisted approaches when analysing the same LLM-integrated software architectures remains insufficiently established.

First, existing approaches can produce substantially different numbers and types of threat findings. Raw output volume does not indicate the proportion of relevant security concerns identified by an approach. Comparative empirical evaluation using common system scenarios and explicit evaluation criteria is therefore necessary to distinguish output volume from reference-threat coverage and precision [7, 24].

Second, threat quantity does not necessarily correspond to threat validity. Generated findings may be irrelevant, redundant, or otherwise incorrect, making it necessary to distinguish the number of generated findings from their correspondence to defined evaluation criteria [17, 20]. This motivates explicit evaluation of precision and the identification of primary true-positive, duplicate, false-positive, and false-negative findings rather than relying solely on generated threat counts.

Third, the relationship between generated threats and the architecture of the analysed system requires explicit consideration. A threat may appear plausible while lacking sufficient evidence that it applies to the system under analysis. Research on architectural representations and threat analysis has emphasized the importance of system elements, data flows, assumptions, and relationships in security analysis [18, 19, 25]. There is therefore a need to consider whether identified threats can be associated with concrete architectural evidence and to distinguish such evidence grounding from correspondence with a reference threat set.

Fourth, reference threat sets provide a useful basis for comparative evaluation but have inherent limitations as measures of completeness. Recent work has highlighted that expert-produced reference models may contain omissions or disagreements and has proposed vulnerability-grounded validation as a complementary evaluation mechanism [1]. Consequently, reference-threat coverage should be interpreted as comparative coverage of the defined reference set rather than as exhaustive evidence that all possible security threats have been identified.

Finally, LLM-based threat modelling introduces additional factors that can affect reproducibility and interpretation, including model choice, prompt formulation, system representation, configuration, and execution conditions [16, 24]. Comparative empirical studies therefore require consistent scenario information and explicit documentation of the conditions under which threat findings are generated.

The research gap can therefore be summarized along three related dimensions. First, there is a comparative gap: classical threat modelling tools, general-purpose LLMs, and LLM-assisted approaches have not been sufficiently characterized to-

gether under the same LLM-integrated system architectures. Second, there is an evaluation gap: differences in output representation, redundancy, false positives, and false negatives make raw threat counts insufficient for comparing the resulting threat sets. Third, there is an evidence gap concerning how the relationship between generated threat findings and concrete architectural evidence can be systematically characterized and distinguished from reference-threat matching and precision.

To address these gaps, this thesis conducts a comparative empirical study of five approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. All five approaches are applied to the same three predefined LLM-integrated software system scenarios. The primary quantitative evaluation considers reference-threat coverage and primary-match precision, while evidence grounding is considered separately as a methodological dimension rather than as a quantitative comparison. Primary true positives, duplicate findings, false positives, and false negatives are retained to characterize the generated findings and their relationship to the expert-vetted reference baseline. Supporting analyses examine normalization, redundancy, STRIDE classification, LLM-specific security threat identification, consistency across repeated LLM executions, and error characteristics.

This positioning defines the contribution of the thesis as a comparative characterization of threat-modelling behaviour under a common experimental setting, rather than an attempt to establish a universally superior approach. In particular, the study distinguishes reference-threat coverage, precision, redundancy, and architectural evidence grounding as related but separate properties of threat-modelling output.

2.6 Summary and Relation to the Present Study

The literature reviewed in this chapter demonstrates an evolution from structured, architecture-driven threat modelling towards increasingly automated and LLM-assisted security analysis [7, 10, 23, 24]. Classical approaches provide established threat taxonomies and structured mechanisms for relating security threats to system architectures [17]. LLM-based approaches provide additional capabilities for interpreting natural-language system descriptions and generating security-related findings from contextual information [10, 24].

The reviewed research also indicates that generated threat sets should not be evaluated using raw threat counts alone. Validity, false positives, reference-threat coverage, architectural representation, and the characteristics of the underlying analysis process are relevant to meaningful evaluation [7, 17, 20]. For LLM-based approaches, additional concerns include redundant or generic findings, architectural grounding, and variation associated with models, prompts, and execution conditions [16, 24].

The literature further shows that LLM-assisted threat modelling is an emerging research area. ThreMoLIA specifically targets threat modelling for LLM-integrated applications, while other studies investigate the use of LLMs within structured threat and privacy modelling activities [9, 10, 15, 16]. Nevertheless, there remains limited evidence from comparative empirical studies that place established architecture-oriented tools, general-purpose LLMs, and LLM-assisted threat modelling approaches under

common experimental conditions.

The present thesis addresses this gap through a comparative empirical evaluation of OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA using three predefined LLM-integrated software system scenarios. The generated findings are evaluated against an expert-vetted reference threat set using predefined mapping criteria and quantitative measures of reference-threat coverage, precision, recall, and F1-score. Evidence grounding is treated separately as a methodological dimension concerning the relationship between generated findings and the specified system architectures. Supporting analyses consider normalization, redundancy, STRIDE classification, LLM-specific security threats, and consistency across repeated LLM executions.

The study therefore extends existing comparative research by examining classical, general-purpose LLM-based, and LLM-assisted approaches within a common experimental setting and by distinguishing reference-threat identification from architectural evidence grounding. The objective is not to establish a universally superior approach, but to characterize differences and potential complementarities among the evaluated approaches under the defined experimental conditions.

This chapter describes the research methodology, experimental design, data collection procedure, and evaluation approach used in this thesis. The study conducts a comparative empirical evaluation of classical, LLM-based, and LLM-assisted threat modelling approaches for analysing LLM-integrated software systems.

The methodology is designed to ensure that the evaluated approaches are applied to the same three predefined system scenarios and that their resulting threat outputs can be systematically collected, preserved, classified, and compared. The chapter describes the research questions, research design, study objects, experimental setup, threat generation procedure, expert reference threat set, data processing, and evaluation criteria. Finally, validity and reliability considerations are discussed to clarify the scope and limitations of the study.

3.1 Research Questions

The study investigates how different threat modelling approaches perform when applied to the same predefined LLM-integrated software system scenarios. The comparison focuses on three primary evaluation dimensions: reference-threat coverage, threat precision, and evidence grounding.

The study addresses the following research questions.

3.1.1 Threat Coverage

RQ1: How does the threat coverage of AI-based threat modelling approaches compare with classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios?

RQ1 evaluates the extent to which each evaluated approach identifies threats represented in the expert-vetted reference threat set for each scenario. The comparison considers the five evaluated approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA.

The expert reference baseline contains 98 reference threats across the three scenarios, comprising 32 reference threats for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. The reference threat set was derived from the scenario architectures by experts from Waibloz AB and is used as the common comparison baseline. It is not treated as exhaustive ground truth, since the absence of a threat from the reference set does not by itself demonstrate that the threat is invalid.

Reference-threat coverage is evaluated by mapping generated findings to the reference threat set for each scenario. The analysis distinguishes between the number of generated findings and the number of reference threats identified, since raw output volume alone does not determine reference-threat coverage.

3.1.2 Threat Precision

RQ2: How does the precision of threat findings generated by AI-based approaches compare with that of classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios?

RQ2 evaluates the proportion of generated findings that correspond to reference threats according to the predefined evaluation and mapping criteria. The analysis therefore focuses on correspondence between generated findings and the expert-vetted reference threat set rather than treating the total number of generated findings as an indicator of quality.

The analysis distinguishes primary true-positive findings, duplicate findings, false-positive findings, and false-negative reference threats. A primary true positive (TP) is a generated finding that corresponds to a reference threat according to the defined semantic and architectural mapping criteria. Additional generated findings that correspond to a reference threat already matched by another finding are classified as duplicates and do not contribute additional reference-threat coverage. A false positive (FP) is a generated finding for which no corresponding reference threat is established under the defined mapping criteria. A false negative (FN) represents a reference threat that is not identified by the evaluated approach.

The evaluation therefore considers precision, recall, and F_1 -score, with the definitions and calculation procedures specified in the evaluation criteria. Raw finding volume and duplicate findings are considered separately from primary precision so that approaches producing different numbers of findings can be compared using a common reference-matching criterion [17, 20].

3.1.3 Evidence Grounding

RQ3: How can the evidence grounding of threat findings generated by AI-based and classical threat modelling approaches be characterized with respect to the architectural evidence of the analysed system scenarios?

RQ3 examines the extent to which an identified threat finding can be connected to concrete evidence from the corresponding system architecture. Evidence considered in the analysis includes explicitly defined system components, data flows, trust boundaries, assets, and security requirements, where applicable. The assessment also considers whether the claimed threat mechanism and security consequence are supported by the properties and relationships represented in the architecture.

Evidence grounding is treated as a distinct analytical dimension from reference-threat matching and threat precision. A finding may be supported by the architecture while not corresponding to a threat in the expert-vetted reference threat set. Conversely, a finding may correspond to a reference threat while requiring a separate assessment of whether the specific formulation and claimed mechanism are

adequately supported by the architecture. Grounding is therefore not inferred from primary true-positive, duplicate, or false-positive classification.

To address RQ3, all 1,025 generated threat findings are assessed against the architectural evidence of the corresponding scenario using a predefined grounding rubric. Each finding is classified as *Fully Grounded*, *Partially Grounded*, *Not Grounded*, or *Unassessable*. A finding is classified as *Fully Grounded* when a specific architectural element or relationship can be identified and the claimed attack mechanism and security consequence are supported by the available architectural evidence. A finding is classified as *Partially Grounded* when an architectural association can be established but the available evidence is incomplete, ambiguous, or does not fully support the claimed mechanism or consequence. A finding is classified as *Not Grounded* when no defensible architectural association can be established or the finding depends on an element, functionality, or relationship that is not present in the specified architecture. A finding is classified as *Unassessable* when the available source material is insufficient to make a grounding determination.

The primary quantitative measure for RQ3 is the *full grounding rate*, defined as the proportion of all generated findings classified as Fully Grounded:

$$G_{\text{full}} = \frac{N_{\text{fully grounded}}}{N_{\text{generated}}} \times 100 \quad (3.1)$$

where $N_{\text{fully grounded}}$ is the number of findings classified as Fully Grounded and $N_{\text{generated}}$ is the total number of findings generated by the evaluated approach before duplicate removal. The Partial, Not Grounded, and Unassessable categories are retained as complementary descriptive results.

The grounding assessment is performed independently of the reference-threat matching analysis. Consequently, grounding classifications are not used to alter the primary true-positive, duplicate, false-positive, or false-negative classifications. This separation allows architectural support and reference-threat correspondence to be examined as related but distinct properties of generated threat findings.

The grounding assessment constitutes a secondary quantitative coding analysis of the original generated findings. It is based on the preserved source outputs and the corresponding scenario architectures. Because the assessment involves analytical judgement and was performed as a single-pass coding assessment without an independent parallel assessor, the resulting grounding rates are interpreted as descriptive measurements under the defined rubric rather than as independently validated inter-rater measurements.

3.2 Research Design

This thesis follows an empirical comparative research design. The objective is to collect and analyse observable evidence in order to answer the research questions. In this study, the evidence consists primarily of threat findings generated by different threat modelling approaches when applied to the same three predefined LLM-integrated software system scenarios.

A comparative design was selected because the objective is not to develop a new threat modelling technique, but to examine similarities, differences, strengths, and

limitations among the evaluated approaches under consistent experimental conditions.

The experimental process consists of five major phases:

1. Scenario preparation

Three predefined LLM-integrated software system scenarios are used. Each scenario provides the system description, architectural representation, components, actors, data flows, trust boundaries, security requirements, information assets, and relevant assumptions required for the threat modelling process.

The three scenarios are kept constant as the underlying experimental subjects across the evaluated approaches. Where an approach requires a specific representation or input format, the scenario information is represented according to the requirements of that approach without changing the underlying system being analysed.

2. Threat generation

Each selected approach is applied to each of the three scenarios using the corresponding scenario information. The five evaluated approaches are:

- OWASP Threat Dragon
- Microsoft Threat Modeling Tool (TMT)
- GPT-5.6
- Llama 3 8B executed through Ollama
- ThreMoLIA

OWASP Threat Dragon and Microsoft Threat Modeling Tool represent the classical, architecture-oriented threat modelling approaches evaluated in the study. GPT-5.6 and Llama 3 8B executed through Ollama represent general-purpose LLM-based approaches, while ThreMoLIA represents an LLM-assisted threat modelling approach specifically designed for LLM-integrated applications.

The generated outputs are retained as the raw experimental results. The original findings are preserved before normalization, duplicate handling, classification, or other subsequent analytical processing.

3. Reference threat set and threat collection

An expert-vetted reference threat set is established for the three scenarios and is used as the common comparison baseline. The reference set contains 98 threats in total, comprising 32 threats for Scenario 1, 33 threats for Scenario 2, and 33 threats for Scenario 3.

The reference threats were derived from the scenario architectures by experts from Waibloz AB. The reference set serves as the evaluation baseline rather than as an exhaustive representation of all possible threats.

The generated outputs are collected and represented in a common analytical structure to enable comparison between approaches. Because the evaluated

approaches produce outputs in different formats and use different terminology, findings are mapped to common analytical fields where the available information permits.

The processing distinguishes between the original generated findings and subsequently normalized findings. Original findings are retained as the primary experimental evidence, while normalization and duplicate or semantic-overlap analysis are performed as separate secondary analytical steps.

The structured representation may include fields such as:

- Threat description
- Threat category
- Affected component or data flow
- Security impact
- Proposed mitigation
- Architectural evidence or grounding

Only information supported by the corresponding generated output or the defined scenario is recorded. Missing information is not inferred solely to make outputs structurally identical.

4. **Threat evaluation**

The collected findings are evaluated using predefined evaluation criteria corresponding to the research questions. The primary evaluation considers reference-threat coverage and threat precision, while evidence grounding is considered as a separate analytical dimension.

For reference-threat mapping, semantic equivalence is considered at the level of the underlying security condition or attack mechanism rather than through wording similarity alone. Architectural evidence is also considered when determining whether a generated finding corresponds to a reference threat.

The evaluation distinguishes primary true positives, duplicate findings, false positives, and false negatives. A primary true positive represents a generated finding that corresponds to a reference threat according to the defined mapping criteria. Additional equivalent findings corresponding to an already matched reference threat are classified as duplicates and do not increase reference-threat coverage. A false positive represents a generated finding for which no corresponding reference threat is established under the defined criteria. A false negative represents a reference threat that is not identified by the evaluated approach.

Supporting analyses, including STRIDE categorization, LLM-specific security mapping, normalization, redundancy, consistency across repeated LLM executions, and error analysis, are conducted separately from the primary evaluation dimensions.

5. Comparative analysis

The evaluated results are compared across the five approaches and three scenarios. The primary comparison examines reference-threat coverage and threat precision, while evidence grounding is considered separately. Supporting analyses provide additional context regarding raw finding volume, normalization, STRIDE classification, LLM-specific security risks, redundancy, and consistency.

The interpretation of the results considers the characteristics and constraints of each approach rather than assuming that one approach is universally superior. In particular, differences in tool functionality, model behaviour, input representation, and output structure are considered when interpreting observed results.

The design keeps the underlying system scenarios and their corresponding architectural and security information consistent across the evaluated approaches. This provides a basis for comparing differences in the resulting threat sets while recognizing that tool capabilities, model behaviour, input representation, and output format may influence the observed results.

3.3 Research Methodology

This thesis follows an empirical software engineering methodology using a comparative research design. The study collects and analyses observable threat modelling outputs to investigate how different threat modelling approaches perform when applied to the same three predefined LLM-integrated software system scenarios.

The selected methodology is appropriate because the objective is to evaluate and compare existing threat modelling approaches rather than to develop a new threat modelling technique. Comparative evaluations of threat modelling approaches have previously been used to examine differences in analysis capabilities, threat identification, and generated results [7, 24].

The study evaluates five approaches: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA. OWASP Threat Dragon and Microsoft Threat Modeling Tool represent the classical, architecture-oriented approaches evaluated in the study. GPT-5.6 and Llama 3 8B executed through Ollama represent general-purpose LLM-based approaches, while ThreMoLIA represents an LLM-assisted threat modelling approach for LLM-integrated applications [10].

The study combines quantitative and qualitative analysis. Quantitative analysis is used to measure characteristics of the collected outputs, including generated finding counts, reference-threat coverage, threat precision, and distributions derived from the threat classifications. Qualitative analysis is used where interpretation of individual findings is required, particularly when assessing semantic correspondence between generated findings and reference threats and when examining available architectural evidence.

A distinction is maintained between raw experimental outputs and subsequent analytical representations. The original outputs are preserved as the primary ex-

perimental evidence. Subsequent extraction, structuring, mapping, normalization, and overlap analysis are performed as analytical operations to support comparison between approaches. These operations do not replace the original generated findings.

The expert-vetted reference threat set is used as the common comparison baseline for the three scenarios. It contains 98 reference threats in total: 32 threats for Scenario 1, 33 threats for Scenario 2, and 33 threats for Scenario 3. The reference threats were derived from the scenario architectures by experts from Waibloz AB. The reference set is used as the evaluation baseline and is not treated as exhaustive ground truth, since the absence of a threat from the reference set does not by itself establish that the threat is invalid.

Generated findings are evaluated against the corresponding scenario reference threat set using predefined coding and semantic mapping criteria. The mapping considers whether a generated finding represents the same underlying security condition or attack mechanism as a reference threat and whether the correspondence is supported by the architecture of the analysed scenario. Wording similarity or membership in the same threat category alone is not considered sufficient to establish a correspondence.

The evaluation distinguishes between primary true-positive (TP), false-positive (FP), and false-negative (FN) outcomes, with duplicate findings handled separately. A TP represents a generated finding that corresponds to a reference threat according to the defined mapping criteria. An FP represents a generated finding for which no corresponding reference threat is established under those criteria. An FN represents a reference threat that is not identified by the evaluated approach. Additional generated findings corresponding to an already matched reference threat are classified as duplicates and do not increase reference-threat coverage.

Evidence grounding is considered separately from reference-threat matching. A finding may correspond to a reference threat while providing different levels of architectural support. Available evidence may include system components, data flows, trust boundaries, assets, and security requirements where applicable. The limitations of the available grounding evidence are considered in the subsequent evaluation and discussion.

The methodology therefore combines comparative threat generation, structured extraction and classification, reference-based evaluation, and comparative analysis. The primary quantitative evaluation focuses on reference-threat coverage and precision, while evidence grounding is considered as a separate analytical dimension. Supporting analyses examine characteristics such as STRIDE categorization, LLM-specific security mapping, normalization, redundancy, consistency across repeated LLM executions, and error patterns.

3.4 Study Object Selection

The selection of suitable study objects is an important aspect of empirical research because the evaluation must reflect the research problem being investigated. This thesis focuses on LLM-integrated software systems and therefore uses three structured LLM-integrated software system scenarios as the study objects.

The three scenarios are evaluated independently. Using multiple scenarios allows

the study to compare the evaluated threat modelling approaches across different system architectures and to examine whether observed differences are specific to an individual scenario or are also present across multiple scenarios.

Each scenario is specified using architectural and functional information relevant to threat modelling. This includes external entities, application processes, LLM-related components, data stores, data flows, trust boundaries, security requirements, information assets, and relevant assumptions as defined by the individual scenario. These architectural specifications also provide the evidence basis for the subsequent assessment of whether generated threat findings are grounded in the corresponding system architecture.

The scenarios contain the following threat modelling elements:

- **External entities**

External entities represent users or external systems that interact with the application and therefore provide potential sources of input or interaction across system boundaries.

- **Application processes**

Application processes represent components that perform processing or business functions and communicate with other components within the system.

- **LLM-related components**

LLM-related components represent the language-model functionality and its integration with the surrounding application. Their inclusion enables the study to examine threats associated with interactions between conventional application components and LLM functionality.

- **Data stores**

Data stores represent repositories containing information used or produced by the system. Depending on the scenario, these may contain user, authentication, session, profile, file, or contextual information relevant to the security analysis.

- **Data flows and trust boundaries**

Data flows describe the movement of information between system elements, while trust boundaries represent changes in trust level between components or security domains. These elements provide architectural context for the identification and evaluation of potential threats.

The scenarios provide sufficiently detailed and structured architectural information for systematic threat analysis while keeping the underlying system definitions fixed during the comparison. The scenario architectures also provide the basis for the expert-vetted reference threat set and the evidence-grounding assessment performed in the evaluation. The scenarios are not intended to represent the complete space of LLM-integrated applications; rather, they provide study objects for evaluating the selected threat modelling approaches.

Before threat generation, the scenario definitions were reviewed to ensure that the architectural and functional information required for analysis was available. The

same underlying scenario definitions were maintained across the experiment. Where an evaluated approach required a particular input or representation format, the scenario information was represented according to that approach without intentionally changing the underlying system architecture or security requirements.

The scenarios therefore provide a common experimental basis while allowing each evaluated approach to operate according to its own input and interaction requirements. This distinction is important because differences in representation, tool functionality, model behaviour, and output structure may influence the resulting threat findings even when the underlying system being analysed remains unchanged.

3.5 Evaluated Approaches

The experimental setup was designed to provide a comparative empirical evaluation of five threat modelling approaches across the three LLM-integrated software system scenarios. The evaluated approaches represent classical architecture-oriented threat modelling tools, a general-purpose cloud-based LLM, a locally executed LLM, and an LLM-assisted threat modelling approach.

The experiment consists of five evaluated approaches:

- **OWASP Threat Dragon**

OWASP Threat Dragon was included as a classical threat modelling approach. It provides a structured environment for representing system architectures and identifying security threats using established threat modelling concepts. The OWASP Top 10 for Large Language Model Applications was used as an LLM-specific security reference during the evaluation where applicable, but it is treated separately from OWASP Threat Dragon as a security taxonomy rather than as the threat modelling tool itself.

- **Microsoft Threat Modeling Tool (TMT)**

Microsoft Threat Modeling Tool was included as a classical, architecture-oriented threat modelling approach based on the STRIDE methodology. The tool analyses architectural elements and data flows and generates threats according to its defined threat modelling rules and categories [17, 22].

The version of the tool used in the experiment is documented with the experimental configuration in the accompanying research artifacts.

- **GPT-5.6**

GPT-5.6 was included as a general-purpose cloud-based LLM approach for threat generation. The model was used through the ChatGPT environment and was provided with the defined system scenarios and corresponding experimental prompts to generate potential security threats. The exact prompts and recorded model configuration are documented in Appendix A.9.

- **Llama 3 8B executed through Ollama**

Llama 3 8B was included as a locally executed LLM-based approach. The model was executed through the Ollama runtime using the recorded `llama3:8b`

configuration. The model was executed locally rather than through an externally hosted inference service. The recorded model configuration and experimental prompts are documented in Appendix A.9.2.

- **ThreMoLIA**

ThreMoLIA was included as an LLM-assisted threat modelling approach designed to support systematic threat generation for LLM-integrated applications [10]. In the experimental configuration, ThreMoLIA used OpenAI’s GPT-4o multimodal model across its documented processing stages, including diagram interpretation (`img_to_text_model`), threat synthesis (`main_model`), and post-generation validation or health scoring (`validation_model`). Semantic category relevance was additionally checked using vector embeddings generated with `text-embedding-3-small`.

Architectural inputs and resulting threat catalogues were persisted as ThreMoLIA session artifacts in the `.thremolia` format. These artifacts retained generated threat entities and associated metadata, including multi-framework alignments, CVSS v3.1 parameters, and session provenance. The resulting threat findings were subsequently extracted and analysed using the evaluation procedure defined in this thesis.

The GPT-4o model used within ThreMoLIA is treated as an internal component of the ThreMoLIA configuration rather than as a separate evaluated approach. The ThreMoLIA version and execution configuration used in the experiment are documented in the associated research artifacts.

Potential researcher involvement: The thesis advisor, Oleksandr Adamov, is involved in the development of ThreMoLIA. This relationship is explicitly disclosed because ThreMoLIA is one of the approaches evaluated in this study. The expert-vetted reference threat baseline was established independently by security experts at Waibloz AB based on the scenario architectures. The same predefined threat-matching procedure and evaluation criteria were subsequently applied to all five approaches. This separation was intended to reduce the potential for researcher influence on the comparative evaluation. The potential conflict of interest is retained as a limitation when interpreting the comparative results.

The evaluated approaches differ in their input representations, interaction mechanisms, and threat-generation procedures. These differences reflect the documented operational configurations of the approaches and constitute an important aspect of the comparative study. The study therefore compares complete threat-modelling approaches as operationalized in their documented configurations, rather than isolating the effect of an underlying model, algorithm, or interface mechanism. Consequently, observed differences in threat coverage, precision, redundancy, and evidence grounding may reflect both the characteristics of the approaches themselves and the way each approach operationalizes the threat-modelling task.

Table 3.1: Input and Interaction Characteristics of the Evaluated Approaches

Approach	Input Representation	Interaction Mechanism	Threat Generation
OWASP Threat Dragon	Structured architecture	Graphical user interface	Tool-based
Microsoft TMT	Structured architecture	Graphical user interface	Tool-based
GPT-5.6	Scenario description and prompt	Natural-language interaction	General-purpose LLM
Llama 3 8B	Scenario description and prompt	Natural-language interaction	Locally executed LLM
ThreMoLIA	Framework-specific architectural input	Structured/LLM-assisted interaction	LLM-assisted threat modelling

3.6 Experimental Setup

The experimental setup was designed to provide a consistent basis for comparing the five evaluated threat modelling approaches across the three predefined LLM-integrated software system scenarios. The underlying scenario definitions, including their architectural, functional, and security information, were kept consistent throughout the experiment.

For each scenario, threat modelling was performed independently using the following five approaches:

- **OWASP Threat Dragon**
- **Microsoft Threat Modeling Tool (TMT)**
- **GPT-5.6**
- **Llama 3 8B executed through Ollama**
- **ThreMoLIA**

OWASP Threat Dragon and Microsoft Threat Modeling Tool represent the classical threat modelling approaches evaluated in the study. GPT-5.6 was used as a general-purpose LLM-based approach through the ChatGPT environment. Llama 3 8B was used as a locally executed LLM through the Ollama runtime. ThreMoLIA was evaluated as an LLM-assisted threat modelling approach [10]. The model configurations, prompts, and available execution information are documented in the corresponding methodological and experimental documentation.

The approaches were applied using the system information required by their respective modelling processes. Although the representation, input format, and interaction procedure could differ between approaches, the underlying system scenario and its defined architectural and security information remained unchanged.

The experiment followed a consistent sequence. First, the corresponding scenario was prepared using its predefined system description and architectural information. Second, each evaluated approach was applied to the scenario to generate or identify potential security threats. Third, the resulting outputs were collected and preserved as raw experimental data. Finally, the collected findings were extracted into the common analytical representation and prepared for subsequent evaluation and comparative analysis.

The raw outputs were preserved before normalization, duplicate analysis, threat mapping, or other analytical transformations were performed. This separation between raw and processed data maintains traceability and ensures that the original experimental findings remain available for verification and reanalysis.

The expert-vetted reference threat set was maintained separately from the generated outputs. It contains 98 reference threats across the three scenarios: 32 threats for Scenario 1, 33 threats for Scenario 2, and 33 threats for Scenario 3. The reference threats were independently identified by security experts from Waibloz AB based on the corresponding scenario architectures. The reference threat set is used as the comparison baseline for reference-threat coverage and is not treated as an exhaustive or absolute ground-truth representation of all possible security threats.

Because the evaluated approaches differ in their underlying technologies, modelling mechanisms, model configurations, and output formats, these differences are considered when interpreting the comparative results. The experimental setup therefore provides a consistent comparative basis while not assuming that the approaches operate internally or produce outputs in identical ways.

3.7 Threat Normalization and Classification

Because the evaluated threat modelling approaches produce outputs in different formats and use different terminology, a normalization and classification process was applied as a secondary analytical step to support systematic comparative analysis. Comparative studies of automated and LLM-based threat modelling similarly highlight the need to account for differences in threat representations when comparing approaches [7, 24].

Normalization was performed after collection of the original outputs and did not replace, modify, or discard the original experimental findings. All raw findings were retained separately to preserve the original results and maintain traceability between the generated outputs and the subsequent analysis.

For comparative analysis, generated findings were represented using a common set of analytical attributes where the available output supported such classification. These attributes included:

- **Threat identifier**

An identifier used to reference and track an individual finding during analysis. This analytical identifier does not replace the identifier used in the original output.

- **Threat description**

The security issue described by the evaluated approach. The original threat description was retained wherever available.

- **Threat category**

The security classification associated with the finding, where such a classification was provided or could be mapped to the analytical classification scheme. The classification may include STRIDE categories and LLM-specific security categories where applicable.

- **Affected component or data flow**

The system component, data store, external entity, or data flow associated with the identified threat, where supported by the generated output and the corresponding scenario architecture.

- **Security impact**

The potential security consequence associated with the finding, where specified by the evaluated approach or supported by the source output.

- **Evidence grounding**

Architectural evidence that may be used to assess whether the finding can be related to explicit elements of the corresponding system architecture, such as components, data flows, trust boundaries, assets, or other explicitly defined properties. Evidence grounding was treated as a distinct analytical dimension and was not assumed solely from the presence of a component, reference-threat match, or threat category.

- **Mitigation information**

The security control or mitigation proposed by the evaluated approach, where such information was included in the original output.

Where an approach did not provide a particular attribute, the missing information was retained as unavailable rather than being inferred or artificially assigned.

Generated findings were subsequently classified according to their relationship with the expert-vetted reference threat set. A primary mapping was assigned when a generated finding represented the same underlying security condition or attack mechanism as a reference threat according to the defined matching criteria. Word-similarity alone, or membership in the same broad threat category, was not considered sufficient to establish a primary mapping. Reference-threat matching and evidence grounding were treated as separate analytical properties; therefore, a primary mapping did not by itself constitute a grounding judgement.

Each generated finding was assigned at most one primary reference mapping. This one-to-one primary mapping prevents a single generated finding from artificially increasing coverage across multiple reference threats. Additional semantic relationships, where relevant, were retained as secondary analytical information rather than being counted as multiple primary matches.

Generated findings were also examined for duplicates and semantic overlap. A duplicate or overlapping finding was identified when it described the same or substantially similar underlying security condition as another generated finding, despite differences in wording, terminology, or presentation. Duplicate findings were retained in the raw dataset and recorded separately from primary true-positive mappings and false positives.

This distinction is important for the evaluation because repeated findings must not artificially increase reference-threat coverage. Within each approach and scenario, at most one generated finding can serve as the primary true-positive mapping for a given reference threat. Additional equivalent findings are treated as duplicates for the corresponding redundancy analysis.

The normalized analysis may produce canonical threat groups where multiple generated findings represent the same underlying threat mechanism. Such canonical groups are analytical representations of the generated findings and are not additional experimental findings.

For the final classification, generated findings were categorized as primary true positives, duplicates, or false positives according to their relationship with the expert-vetted reference baseline. A primary true positive represents a distinct generated finding that was accepted as the primary correspondence to a reference threat. A duplicate represents an additional generated finding corresponding to an underlying threat already represented by a primary mapping. A false positive represents a generated finding for which no corresponding reference threat was identified under the matching criteria. After classification of the generated findings, reference threats for which no primary generated finding was identified were counted as false negatives at the approach level.

Ambiguous mappings were reviewed using the predefined coding criteria and the available source information. Low-confidence primary mappings were subjected to a separate final adjudication process to determine whether the original classification should be retained or whether the associated reference-threat assignment should be changed. A total of 27 low-confidence primary mapping cases were reviewed. Of these, 20 were retained as primary true positives and 7 resulted in changes to the associated reference-threat assignment. No reviewed case was changed from a primary true positive to a false positive, and no new reference threats were added to the evaluation baseline. The adjudication therefore did not change the aggregate number of primary true positives in the final evaluation dataset.

The adjudication process should not be interpreted as a formal inter-rater reliability assessment. The available research records do not contain independent parallel classifications from multiple assessors from which a formal agreement statistic, such as Cohen's κ , could be calculated. The adjudication is therefore reported as a quality-control procedure for ambiguous matching decisions rather than as quantitative evidence of inter-rater agreement.

The normalized analysis does not replace the raw threat counts or the primary generated-finding dataset. Raw findings remain the primary experimental outputs, while normalized and unique threat representations are used as secondary analytical representations where required for cross-approach comparison. This distinction ensures that differences in the volume of generated findings remain observable while also allowing the analysis to examine semantic overlap, redundancy, and distinct

security issues.

All classification and normalization decisions were based on the generated outputs and the corresponding scenario definitions. No threat was introduced solely to make the outputs comparable, and unsupported information was not added during the normalization process.

3.8 Evaluation Criteria

The evaluation is based on three primary criteria corresponding to the main comparative dimensions of the study: reference-threat coverage, threat precision, and evidence grounding. Additional analyses, including threat categorization, STRIDE distribution, overlap and redundancy, LLM-specific security mapping, run-to-run consistency, and error analysis, are used as supporting analyses for interpreting the primary findings.

The evaluation is performed at the level of individual generated findings. The original generated findings are retained as the primary experimental data, while normalized representations are used only for secondary analyses where semantic overlap or consolidation is required.

3.8.1 Threat Coverage

Threat coverage evaluates the extent to which an evaluated approach identifies threats represented in the expert-vetted reference threat set for the corresponding scenario. This reflects the use of completeness- or recall-oriented measures in empirical evaluations of threat modelling results [17, 20].

For each scenario, generated findings are compared with the corresponding expert-vetted reference threat set using the defined threat-mapping procedure. A reference threat contributes to coverage when it is identified by at least one valid primary mapping from the generated findings.

The expert-vetted reference threat set contains 98 reference threats in total, consisting of 32 threats for Scenario 1, 33 threats for Scenario 2, and 33 threats for Scenario 3. The reference threats were independently identified by security experts from Waibloz AB based on the scenario architectures. The reference threat set is used as an expert-vetted comparison baseline and is not treated as an exhaustive or absolute ground-truth representation of all possible security threats.

Threat coverage is calculated as:

$$\text{Coverage (Recall)} = \frac{\text{Distinct Reference Threats Identified}}{\text{Total Reference Threats}} \times 100 \quad (3.2)$$

In information-retrieval terminology, the distinct reference threats successfully identified by an approach correspond to primary *true positives* (*TP*), while reference threats not identified by the approach correspond to *false negatives* (*FN*). Thus, coverage can equivalently be expressed as:

$$\text{Recall} = \frac{TP}{TP + FN} \times 100 \quad (3.3)$$

The coverage calculation is based on distinct reference threats identified rather than on the total number of generated findings. Consequently, an approach that generates a larger number of findings does not automatically achieve higher coverage.

False negatives are reference threats for which no valid primary mapping is established among the generated findings for the corresponding approach and scenario.

Duplicate findings do not increase recall. When multiple generated findings correspond to the same reference threat, only one finding is assigned the primary true-positive mapping for that reference threat; additional equivalent findings are recorded as duplicates. This preserves the distinction between reference-threat coverage and redundancy in the generated output.

This criterion primarily addresses RQ1.

3.8.2 Precision

Precision measures the proportion of non-duplicate generated findings that were classified as primary true positives among the findings classified as primary true positives or false positives. Because duplicate findings are retained as a separate analytical category, they are excluded from the primary-match precision denominator.

Primary-match precision is therefore calculated as:

$$P = \frac{TP_p}{TP_p + FP} \quad (3.4)$$

where TP_p represents primary true-positive findings and FP represents false-positive findings.

This measure captures the correspondence of distinct generated findings with the expert-vetted reference threat baseline under the defined threat-matching criteria. Duplicate findings are not counted as additional true positives or false positives because they represent repeated descriptions of an underlying security concern already represented by another finding. However, duplicate findings remain part of the complete raw output and are reported separately through the redundancy analysis.

To provide complementary context on the effect of duplicate findings, primary-match yield is also reported as a secondary descriptive measure. It is calculated as:

$$Y = \frac{TP_p}{N_{\text{generated}}} \quad (3.5)$$

where $N_{\text{generated}}$ represents the total number of findings generated by an approach before duplicate removal. Unlike primary-match precision, primary-match yield retains duplicate findings in the denominator and therefore indicates the proportion of the complete raw output that resulted in primary reference-threat matches.

Primary-match precision and primary-match yield capture different aspects of the generated threat output. Primary-match precision describes the proportion of non-duplicate findings that correspond to the expert-vetted reference threat baseline, whereas primary-match yield reflects the effect of duplicate findings on the complete raw output. Both measures are therefore interpreted together with recall, false positives, false negatives, and redundancy rather than as standalone measures of overall threat-modelling effectiveness.

Neither primary-match precision nor primary-match yield is interpreted as a direct measure of analyst usefulness or review efficiency. Such an assessment would require additional evidence concerning analyst effort, consolidation effort, or validated usability measures, which were not collected systematically in this study.

3.8.3 Evidence Grounding

Evidence grounding is treated as a distinct analytical dimension that examines whether a generated threat finding is supported by explicit evidence from the architecture of the corresponding system scenario. It distinguishes merely plausible threats from findings whose claimed security condition is supported by properties and relationships explicitly represented in the analysed system.

Grounding is assessed through two complementary requirements: *structural binding* and *semantic support*. Structural binding concerns whether the finding can be connected to a specific architectural element or relationship, such as a system component, data flow, trust boundary, asset, security requirement, or other explicitly defined architectural property. Semantic support concerns whether the claimed attack mechanism and security consequence are supported by the properties and relationships present in the architecture. Thus, merely naming an actual component or data flow does not establish grounding if the claimed attack mechanism is not supported by the architecture.

For the quantitative grounding assessment, each of the 1,025 original generated findings is evaluated against the architectural evidence of its corresponding scenario before any aggregation of grounding results. Duplicate findings are therefore assessed individually to characterize the architectural support of the complete generated output. The assessment is independent of reference-threat matching and does not modify the primary true-positive, duplicate, false-positive, or false-negative decisions.

For analytical purposes, evidence grounding is classified into four categories:

- **Fully grounded:** A specific architectural element or relationship can be identified, and the claimed attack mechanism and security consequence are supported by the available architectural evidence.
- **Partially grounded:** An architectural association can be established, but the available evidence is incomplete, ambiguous, or does not fully support the claimed attack mechanism or security consequence. This also includes findings for which the architectural context is supported but the claimed mechanism depends on implementation details, configuration, infrastructure, or capabilities not explicitly represented in the specified architecture.
- **Not grounded:** No defensible architectural association can be established, or the finding depends on an element, functionality, or relationship not present in the specified architecture.
- **Unassessable:** The available source material is insufficient to make a grounding determination because the original generated finding or the corresponding architectural evidence required for assessment cannot be established from the preserved research material.

The distinction between structural binding and semantic support determines the grounding classification. Full grounding requires both an identifiable architectural association and sufficient support for the claimed threat mechanism and security consequence. Where an architectural association exists but the evidence does not fully support the complete claim, the finding is classified as partially grounded.

The primary quantitative measure for RQ3 is the *full grounding rate*, defined as the proportion of all generated findings classified as Fully Grounded:

$$G_{\text{full}} = \frac{N_{\text{fully grounded}}}{N_{\text{generated}}} \times 100 \quad (3.6)$$

where $N_{\text{fully grounded}}$ is the number of generated findings classified as Fully Grounded and $N_{\text{generated}}$ is the total number of findings generated by the evaluated approach before duplicate removal.

The Partially Grounded, Not Grounded, and Unassessable categories are retained as complementary descriptive measures and are not combined with Fully Grounded when calculating the primary full grounding rate, because partial architectural support does not establish the same level of evidence as complete support. The category distribution is nevertheless reported to characterize the nature of the observed grounding.

Grounding is deliberately independent of the reference-threat matching decision. A finding may be Fully Grounded while remaining a false positive relative to the expert-vetted reference threat set if its security concern is architecturally supported but absent from that baseline. Conversely, a finding may correspond to a reference threat while receiving a lower grounding classification if its specific formulation, attack mechanism, or security consequence is not sufficiently supported by the available architectural evidence. Grounding therefore characterizes architectural support rather than reference-threat correctness.

The grounding assessment is a secondary quantitative coding analysis of the preserved original generated outputs and corresponding scenario architectures. It involves analytical judgement and was conducted as a single-pass assessment without an independent parallel assessor. Consequently, the reported grounding rates are interpreted as descriptive measurements under the defined coding rubric rather than as independently validated inter-rater measurements. No inter-rater reliability statistic, such as Cohen’s κ , is therefore reported.

This criterion primarily addresses RQ3.

3.8.4 Supporting Evaluation Analyses

In addition to the three primary evaluation criteria, supporting analyses are performed to provide additional context for interpreting the comparative results.

- **Threat categorization:** Generated findings are classified according to the applicable threat categories, including STRIDE categories where applicable.
- **LLM-specific security mapping:** Generated findings are examined with respect to relevant LLM-specific security categories where such mappings are available and can be evaluated.

- **Normalization and redundancy:** Semantically equivalent or overlapping findings are examined to determine the degree of redundancy in the generated outputs. The normalized representation does not replace the original generated findings.
- **Run-to-run consistency:** Where multiple experimental runs are available, consistency is evaluated using the recorded intersection, union, stability, and Jaccard similarity measures.
- **Error analysis:** Incorrect, unsupported, or otherwise problematic findings identified during the evaluation are analysed to characterize limitations in the generated outputs. This includes analysis of false-positive and false-negative patterns where the corresponding classification has been established.

These supporting analyses do not constitute separate primary research questions. Instead, they provide additional evidence for interpreting the differences observed in coverage, precision, and evidence grounding.

3.9 Data Collection and Management

All experimental data generated during the study were collected and organized to maintain traceability between the experimental scenarios, threat modelling inputs, generated outputs, and subsequent analytical results.

The collected research artifacts consist of:

- System scenario definitions and architectural descriptions;
- Threat modelling diagrams and architectural representations;
- Tool-generated threat modelling outputs;
- LLM-generated threat outputs;
- The expert-vetted reference threat set used for comparative evaluation;
- Structured and normalized threat datasets;
- Per-finding grounding assessments based on the original generated findings and the corresponding scenario architectures;
- Evaluation and master spreadsheets;
- Experimental prompts and model configuration information; and
- Comparative analysis results.

The original outputs generated by each evaluated approach were preserved separately from the processed analysis data. Raw outputs were retained before structuring, classification, normalization, duplicate analysis, grounding assessment, or other analytical transformations. This separation ensures that the original experimental

findings remain available for verification and potential reanalysis without being overwritten by subsequent processing.

The expert-vetted reference threat set was maintained separately from the generated outputs. It contains 98 reference threats across the three scenarios: 32 for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. The reference threats were independently identified by security experts from Waibloz AB based on the corresponding scenario architectures and were subsequently used to establish the common comparison baseline for the five evaluated approaches.

The available research records document the resulting reference threat set and its scenario-level distribution, but do not retain sufficient methodological information to report the exact number of participating experts, their individual qualifications, the complete pre-reconciliation threat lists produced by each expert, or a formal inter-expert agreement statistic. These details are therefore not inferred or reconstructed in this study. The reference threat set is treated as an expert-vetted comparison baseline rather than as an exhaustive or absolute ground-truth representation of all possible threats.

The per-finding grounding assessment was maintained separately from the reference-threat matching classifications. For each generated finding, the grounding assessment records the corresponding approach and scenario together with its grounding category and the rationale used to characterize its relationship to the available architectural evidence. The grounding assessment was performed on the original generated findings and was not used to modify the reference-threat matching decisions. This separation preserves the distinction between architectural evidence grounding and reference-threat correspondence.

The research artifacts were organized using version control. Only research materials approved for sharing were included in the public repository; confidential or non-approved Waibloz AB materials were excluded. Version control supports traceability of the research artifacts that are available for sharing and records changes made during the preparation and analysis of the study.

The data management process distinguishes between three levels of experimental data:

1. **Raw experimental outputs**, representing the findings produced directly by the evaluated approaches before analytical processing;
2. **Processed datasets**, representing findings that have been structured, classified, mapped, normalized, or otherwise prepared for analysis, including the per-finding grounding classifications; and
3. **Evaluation results**, representing the measurements, summaries, and comparative analyses derived from the processed datasets.

Raw experimental outputs were not altered as a consequence of subsequent processing. The separation between raw evidence, processed datasets, and evaluation results preserves the distinction between findings generated by the evaluated approaches and results derived through subsequent analysis. This separation also supports traceability from the original generated findings to the reference-threat classifications, grounding assessments, and comparative results reported in the thesis.

3.10 Validity and Reliability of the Approach

The validity and reliability of the study are considered in relation to the research questions, experimental design, threat classification procedure, and interpretation of the comparative results. The main considerations concern construct validity, internal validity, external validity, reliability, and methodological limitations.

3.10.1 Construct Validity

Construct validity concerns whether the evaluation criteria adequately represent the concepts investigated by the research questions.

The primary evaluation dimensions are reference-threat coverage, threat precision, and evidence grounding. Reference-threat coverage measures the extent to which generated findings identify threats represented in the expert-vetted reference threat set. Threat precision measures the proportion of generated findings that constitute primary matches among the findings included in the precision calculation. Evidence grounding is considered as a separate analytical dimension describing the relationship between generated findings and explicit architectural evidence.

A potential construct-validity concern is that the effectiveness of a threat modelling approach cannot be adequately represented by the number of generated findings alone. An approach may generate many findings while also producing false positives, redundant findings, or findings with limited architectural support. Empirical threat modelling research has similarly distinguished between completeness and false-positive findings when evaluating threat modelling results [17, 20].

To address this concern, the study considers multiple evaluation dimensions. Reference-threat coverage is measured using recall, while primary-match precision evaluates the correspondence of generated findings with the reference threat set. Duplicates are analysed separately from primary true-positive mappings and false positives. Primary-match yield is also used as a complementary measure to retain the effect of duplicate findings in the denominator of the complete generated output.

The reference threat set is an expert-vetted comparison baseline rather than an exhaustive representation of all possible security threats. Consequently, the evaluation measures correspondence with the established reference set rather than complete security coverage of the analysed systems.

Evidence grounding is treated separately from reference-threat matching. Consequently, a primary reference-threat match does not by itself establish that the generated finding is fully supported by the architecture.

Supporting analyses, including STRIDE categorization, LLM-specific security mapping, redundancy, run-to-run consistency, and error analysis, provide additional context for interpreting the primary measures.

3.10.2 Internal Validity

Internal validity concerns whether observed differences between the evaluated approaches can reasonably be interpreted in relation to the approaches and their observed behaviour rather than differences in the underlying scenario information.

A potential threat to internal validity is that the evaluated approaches use different modelling mechanisms, input representations, execution environments, and output formats. Classical tools use structured modelling mechanisms, whereas LLM-based approaches rely on natural-language input and model inference. The approaches therefore cannot be expected to operate internally in an identical manner [10, 24].

To reduce variation in the underlying system being analysed, the same three predefined scenario definitions were used throughout the experiment. Their defined architectural and security information was kept consistent across the evaluated approaches.

For the general-purpose LLM approaches, the corresponding scenario prompts were used for GPT-5.6 and Llama 3 8B executed through Ollama. The underlying model and execution environment nevertheless differed between these approaches. The prompts, model identifiers, and available configuration information are documented in Appendix A.9 and the associated research artifacts.

A further consideration is the probabilistic nature of LLM-generated outputs. Different executions may produce different findings even when the scenario and prompt remain unchanged. Where multiple runs were available, run-to-run consistency was therefore examined using the recorded overlap and Jaccard-based measures [16, 24].

Differences in tool functionality, model behaviour, prompt formulation, configuration, and interaction procedures remain potential sources of variation and are considered when interpreting the comparative results.

3.10.3 External Validity

External validity concerns the extent to which the findings can be generalized beyond the systems and experimental conditions included in the study.

The study evaluates three predefined LLM-integrated software system scenarios and five threat modelling approaches. Although the scenarios provide different architectural contexts, they cannot represent the full range of LLM-integrated software systems.

The objective is therefore not to establish universal performance rankings for classical or LLM-based threat modelling. Instead, the study identifies observed differences, strengths, limitations, and patterns within the selected experimental conditions.

The findings are consequently bounded by the selected scenarios, evaluated approaches, model and tool configurations, and evaluation criteria. They should not be interpreted as universal claims about the relative effectiveness of the evaluated approaches.

Future research could extend the evaluation to additional scenarios, application domains, architectural patterns, model configurations, and industrial systems.

3.10.4 Reliability

Reliability concerns the consistency and traceability of the experimental procedure and analytical process.

The study documents the principal research artifacts and procedures, including:

- System scenario descriptions and architecture diagrams;
- Data-flow definitions and trust boundaries;
- Threat generation procedures;
- Experimental prompts and available model configurations;
- Generated threat outputs;
- The expert-vetted reference threat set;
- Evaluation criteria and mapping rules;
- Data processing and normalization procedures; and
- Comparative evaluation results.

Generated threat outputs were preserved in their original form before analytical processing. This allows subsequent structuring, classification, mapping, normalization, and duplicate analysis to be traced back to the original findings.

Ambiguous mappings were reviewed using the predefined evaluation criteria and available source information. A documented low-confidence adjudication process was applied to 27 low-confidence primary true-positive cases. Of these, 20 were retained as primary true positives and 7 resulted in changes to the associated reference-threat assignment. No case was changed from primary true positive to false positive, and no new reference threats or generated findings were introduced. The aggregate number of primary true positives therefore remained unchanged after adjudication.

The adjudication process should not be interpreted as a formal inter-rater reliability assessment. The available research records do not contain independent parallel classifications from multiple assessors from which a formal agreement statistic, such as Cohen's κ , could be calculated. The adjudication is therefore treated as a quality-control mechanism for ambiguous matching decisions rather than as statistical evidence of inter-rater agreement.

The use of predefined evaluation criteria and preservation of raw outputs reduces the risk of undocumented changes during analysis. Nevertheless, LLM-based outputs may vary with model versions, configurations, prompts, and repeated executions [16, 24]. The reported results therefore describe the outputs obtained under the documented experimental conditions rather than assuming deterministic behaviour.

3.10.5 Methodological Limitations

Several limitations should be considered when interpreting the results.

First, the evaluation concerns threat modelling outputs for three selected scenarios and five approaches and does not constitute complete security assurance. The findings therefore describe the behaviour of the evaluated approaches under the defined experimental conditions rather than establishing the presence or absence of all security threats in the analysed systems.

Second, GPT-5.6 and Llama 3 8B executed through Ollama depend on the selected models, prompts, configurations, and execution conditions, which may affect

the results [16, 24]. The findings therefore characterize the specific model and execution configurations used in this study rather than all LLM-based threat-modelling approaches.

Third, threat mapping, classification, and evidence grounding involve analytical judgement. The defined coding criteria and documented adjudication process were used to reduce subjectivity. Twenty-seven low-confidence primary true-positive mappings were reviewed during adjudication: 20 were retained as primary true positives and 7 resulted in changes to the associated reference-threat assignment. No case was changed from primary true positive to false positive, no new reference threats or generated findings were introduced, and the aggregate number of primary true positives remained unchanged. However, independent parallel classifications were not retained, preventing calculation of a formal inter-rater reliability statistic such as Cohen’s κ . The same limitation applies to the grounding assessment, which was conducted as a single-pass coding analysis for all 1,025 original generated findings using the predefined grounding rubric and corresponding scenario architectures. The resulting grounding rates should therefore be interpreted as descriptive measurements rather than independently validated inter-rater measures or objective measures of threat correctness.

Fourth, the expert-vetted reference threat set contains 98 threats and serves as a comparison baseline rather than an exhaustive representation of all possible threats. The available research records do not provide sufficient detail to reconstruct the complete expert-level threat elicitation and reconciliation process, including the exact number and qualifications of the participating experts, their independent pre-reconciliation threat sets, or formal agreement statistics. Consequently, recall measures correspondence with the defined reference set and should not be interpreted as complete security coverage of the analysed systems.

Fifth, the experimental comparison does not provide identical interaction mechanisms across all approaches. Classical tools operate through their native structured modelling interfaces and analysis mechanisms, whereas GPT-5.6 and Llama 3 8B were provided with scenario-specific natural-language prompts containing explicit threat-modelling requirements. The comparison therefore evaluates outputs under the documented operating procedures rather than isolating the effect of the underlying modelling mechanism alone. This input and interaction asymmetry is a potential source of variation in the observed results.

Sixth, the study did not collect stopwatch-based efficiency measurements or conduct a formal multi-participant System Usability Scale (SUS) study. Efficiency and standardized usability are therefore not treated as primary empirical evaluation dimensions. Practitioner feedback from Waibloz AB is used as qualitative contextual evidence rather than as a statistically generalizable usability evaluation.

Finally, the findings are bounded by the selected architectures, approaches, model and tool configurations, and experimental conditions and should not be interpreted as universal rankings of classical or AI-based threat-modelling approaches.

These limitations define the scope within which the findings should be interpreted. Future studies could strengthen the evidence through additional scenarios, repeated executions, systematic efficiency measurements, multi-participant usability studies, independent parallel classifications, more detailed documentation of expert reference-set construction, alternative model configurations, and larger industrial cases.

3.11 Practical Relevance and Practitioner Perspective

The study includes a supplementary practitioner perspective to provide qualitative context regarding the practical usefulness and perceived quality of selected threat modelling outputs. This perspective does not constitute an independent benchmark and does not replace the systematic evaluation of reference-threat coverage and precision.

The practitioner perspective is used to contextualize how differences observed in the experimental analysis may relate to practical software security review activities.

3.11.1 Practitioner Feedback Design

The practitioner feedback was collected to obtain qualitative observations on the practical usefulness and perceived quality of selected threat modelling reports. It was not intended to establish the correctness of individual threat findings or independently validate the quantitative evaluation.

The feedback was provided by **Rickard Erwinson of Waibloz AB**, who reviewed two threat modelling reports generated for the same system scenario:

- an LLM-based threat modelling report generated using GPT-5.6 through the ChatGPT environment; and
- a classical threat modelling report generated using OWASP Threat Dragon.

The feedback addressed practical characteristics of the selected outputs, including:

- clarity and understandability;
- relevance of identified threats;
- actionability of security recommendations;
- usefulness during security review activities; and
- overall perceived quality.

Open-ended feedback also captured observations concerning strengths, weaknesses, missing threats, and possible improvements.

The practitioner feedback was analysed qualitatively and is used as supporting contextual evidence when discussing the practical implications of the comparative findings.

3.11.2 Role and Limitations of Practitioner Feedback

The practitioner feedback was not used to determine the correctness of individual threat mappings or quantitative coverage and precision measurements. These aspects remain part of the systematic evaluation procedure described earlier in this chapter.

The practitioner perspective is therefore treated as qualitative contextual evidence rather than as an independent ground truth or quantitative validation of the experimental results. Its purpose is to provide additional industry context concerning the interpretability, perceived usefulness, and practical relevance of selected threat modelling outputs.

The practitioner perspective is also distinct from the expert-vetted reference threat set used as the quantitative comparison baseline. The reference threat set provides the baseline for systematic threat comparison, whereas the practitioner feedback provides qualitative observations about selected generated outputs.

The feedback was obtained from a single practitioner and concerned only selected reports. It therefore does not constitute a formal usability study or provide statistically generalizable conclusions about practitioner preferences or industry-wide usability. In particular, the study did not collect a standardized System Usability Scale (SUS) score or sufficient participant data for a statistical usability evaluation.

3.11.3 Generative AI Use and Experimental Configuration

Generative artificial intelligence was used in this study in two distinct contexts. First, LLM-based systems were evaluated as experimental threat modelling approaches. GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA were provided with the defined system scenarios and used to generate threat modelling outputs. These outputs constitute experimental data and were subsequently collected, structured, classified, and evaluated according to the methodology described in this chapter.

Second, generative AI was used during preparation of the thesis for language refinement, restructuring, and other editorial assistance where applicable. Such use is distinguished from the experimental use of LLMs as threat modelling approaches. The authors remained responsible for the interpretation of the results, methodological decisions, factual accuracy, and final content of the thesis.

The experimental use of generative AI and its use during thesis preparation are therefore treated separately. The exact experimental prompts, model identifiers, and available configuration information are documented in Appendix A.9 and the associated configuration subsections.

4.1 Overview of Results

This chapter presents the results of the comparative evaluation of the five threat modelling approaches across the three LLM-integrated system scenarios: OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA.

The results are presented in several stages. First, the size and distribution of the raw experimental dataset are reported. The analysis then evaluates the generated findings against the corresponding expert-vetted reference threat set. The primary analysis covers reference-threat coverage and threat precision, while evidence grounding is examined as a separate quantitative analytical dimension using the predefined per-finding grounding rubric. Supporting analyses examine threat categorization, STRIDE distribution, overlap and redundancy, LLM-specific security mapping, run-to-run consistency, and error patterns.

Raw experimental outputs are distinguished from processed and normalized datasets throughout the chapter. Raw findings represent the direct outputs produced by the evaluated approaches and remain the primary experimental evidence. Processed datasets are used to structure and evaluate these findings, while normalized representations are used for secondary analyses such as semantic overlap and redundancy. These transformations do not replace the original findings used in the primary matching analysis.

The expert-vetted reference threat set contains 98 reference threats across the three scenarios: 32 for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. The reference threats were independently identified by security experts from Waibloz AB based on the corresponding scenario architectures and are used as the controlled comparison baseline for reference-threat coverage and matching. The reference threat set provides a common evaluation target across all five approaches but is not treated as an exhaustive representation of all possible security threats or as absolute ground truth.

The purpose of this chapter is to report the empirical results and describe the observed differences between the evaluated approaches using the predefined evaluation criteria. Raw finding volume is therefore interpreted as descriptive information rather than as a direct measure of threat modelling effectiveness.

4.2 Dataset Overview

The final experimental dataset contains the raw threat modelling outputs collected from the five evaluated approaches across the three predefined LLM-integrated system scenarios.

Across the three scenarios, the approaches produced 1,025 raw threat findings. Table 4.1 presents the distribution of these findings by approach.

Table 4.1: Distribution of Raw Threat Findings Across the Three Scenarios

Approach	Raw Findings
OWASP Threat Dragon	123
Microsoft Threat Modeling Tool (TMT)	301
GPT-5.6	181
Llama 3 8B executed through Ollama	92
ThreMoLIA	328
Total	1,025

The raw finding counts describe the volume of findings produced by each approach under the experimental conditions of the study. The observed differences in output volume reflect differences in modelling mechanisms, generation strategies, granularity, and output representation, rather than effectiveness alone.

Raw finding volume should not be interpreted as a direct measure of threat modelling effectiveness. The evaluated approaches differ in their modelling mechanisms, generation strategies, granularity, and output formats. Consequently, a larger number of findings may include repeated or overlapping representations of the same underlying security concern, as well as findings that do not correspond to the expert-vetted reference threat set. The subsequent analysis therefore distinguishes primary true-positive matches, duplicates, false positives, and false negatives rather than evaluating approaches solely by output volume.

The raw dataset is therefore treated as descriptive evidence of output volume and as the starting point for the subsequent comparative analysis. The primary evaluation is based on correspondence between generated findings and the expert-vetted reference threat set, with duplicates and false positives retained as separate analytical outcomes.

4.3 Threat Normalization Results

Normalization was used as a secondary analytical operation to support the comparison of findings that described semantically equivalent or overlapping security issues using different terminology, levels of granularity, or output formats.

The normalization procedure grouped findings representing the same underlying security issue using characteristics such as the security condition or attack mechanism, affected architectural element, and relevant security property. The resulting normalized or canonical groups represent an analytical unit distinct from the original generated findings.

For ThreMoLIA, the 328 raw findings generated across the three scenarios were subjected to secondary semantic normalization. The normalized representation is not treated as a replacement for the raw experimental output and does not change the reported raw finding count.

Normalized values are reported only where the corresponding source data and normalization procedure are available. No normalized value is inferred solely from the raw finding count. The normalized representation is used primarily to examine semantic overlap, uniqueness, and redundancy among generated findings.

4.4 Reference Threat Coverage Analysis

The generated findings were compared against the expert-vetted reference threat set for each scenario. The reference threat set contains 98 threats in total: 32 for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3.

For each approach and scenario, a reference threat was counted as identified when at least one generated finding received a valid Primary True Positive mapping to that reference threat according to the threat-matching procedure defined in Chapter 3. Under the one-to-one matching rule, each reference threat can contribute at most one Primary True Positive within an approach–scenario evaluation. Additional equivalent findings are classified as duplicates and do not increase coverage.

Reference-threat coverage was operationalized as reference-threat recall and calculated as:

$$\text{Reference-Threat Recall} = \frac{\text{Distinct Reference Threats Identified}}{\text{Total Reference Threats}} \times 100 \quad (4.1)$$

The analysis therefore measures the proportion of the expert-vetted reference threat set identified by each approach rather than the proportion of generated findings that appear relevant. This distinction prevents differences in raw output volume or duplicate findings from directly inflating the reference-threat recall measure.

The results show that ThreMoLIA achieved the highest reference-threat coverage in all three scenarios, with coverage of 81.25% in S1, 69.70% in S2, and 60.61% in S3. GPT-5.6 achieved the second-highest coverage in each scenario, with 56.25%, 54.55%, and 48.48%, respectively. Microsoft Threat Modeling Tool (TMT), Llama 3 8B via Ollama, and OWASP Threat Dragon achieved lower reference-threat coverage under the same evaluation procedure. The relative ordering was stable across all three scenarios, although the absolute coverage varied by scenario and approach.

4.5 Threat Precision Analysis

Threat precision was evaluated by comparing the generated findings with the expert-vetted reference threat set using the threat-matching procedure described in Chapter 3. The analysis distinguishes Primary True Positive (TP), False Positive (FP), and duplicate findings. Primary True Positives represent valid primary mappings to distinct reference threats, whereas false positives are generated findings for which no valid reference mapping was established. Duplicate findings represent repeated

Table 4.2: Reference-Threat Coverage Across the Three Scenarios

Scenario	Approach	Matched	Coverage (%)
S1	OWASP Threat Dragon	6	18.75
S1	Microsoft Threat Modeling Tool	9	28.13
S1	GPT-5.6	18	56.25
S1	Llama 3 8B via Ollama	6	18.75
S1	ThreMoLIA	26	81.25
S2	OWASP Threat Dragon	6	18.18
S2	Microsoft Threat Modeling Tool	10	30.30
S2	GPT-5.6	18	54.55
S2	Llama 3 8B via Ollama	7	21.21
S2	ThreMoLIA	23	69.70
S3	OWASP Threat Dragon	7	21.21
S3	Microsoft Threat Modeling Tool	9	27.27
S3	GPT-5.6	16	48.48
S3	Llama 3 8B via Ollama	7	21.21
S3	ThreMoLIA	20	60.61

or semantically overlapping representations of a security condition that had already been represented by a primary finding.

Primary-match precision was calculated as:

$$\text{Primary-Match Precision} = \frac{TP}{TP + FP} \times 100 \quad (4.2)$$

Because duplicate findings are recorded separately, they are excluded from the precision denominator. Consequently, the reported precision represents the proportion of findings included in the primary precision calculation that correspond to the expert-vetted reference threat set. It does not represent the proportion of all raw generated findings that constitute primary true-positive matches.

Table 4.3 presents the total generated findings, Primary True Positives, False Positives, duplicate findings, primary-match precision, and primary-match yield for each approach.

Table 4.3: Threat Precision, Duplicates, and Primary-Match Yield

Approach	Generated	TP	FP	Duplicates	Precision (%)	Yield (%)
OWASP Threat Dragon	123	19	79	25	19.39	15.45
Microsoft Threat Modeling Tool	301	28	221	52	11.24	9.30
GPT-5.6	181	52	57	72	47.71	28.73
Llama 3 8B via Ollama	92	20	46	26	30.30	21.74
ThreMoLIA	328	69	95	164	42.07	21.04

The results show that GPT-5.6 achieved the highest primary-match precision at 47.71%, followed by ThreMoLIA at 42.07%, Llama 3 8B via Ollama at 30.30%, OWASP Threat Dragon at 19.39%, and Microsoft Threat Modeling Tool at 11.24%. Thus, GPT-5.6 produced the highest proportion of primary reference-threat matches among findings included in the primary precision calculation.

Primary-match yield provides a complementary view of the complete raw output. GPT-5.6 achieved the highest primary-match yield at 28.73%, followed by Llama 3 8B via Ollama at 21.74%, ThreMoLIA at 21.04%, OWASP Threat Dragon at 15.45%, and Microsoft Threat Modeling Tool at 9.30%. The difference between precision and yield is particularly relevant for ThreMoLIA: although it achieved 42.07% primary-match precision, only 21.04% of its 328 raw findings were primary true-positive matches. This difference reflects the exclusion of duplicate findings from the primary precision denominator and the substantial number of duplicate findings generated by ThreMoLIA.

The results therefore indicate that primary-match precision and primary-match yield capture different aspects of threat-generation output. Precision characterizes the correspondence of primary findings with the expert-vetted reference threat set, whereas primary-match yield contextualizes this correspondence against the complete raw output. Duplicate findings provide a further indication of redundancy and are therefore considered separately rather than being treated as either true positives or false positives.

Overall, GPT-5.6 achieved the highest primary-match precision, while ThreMoLIA produced the highest number of primary true-positive matches and, as shown in Section 4.4, the highest reference-threat recall. These results indicate that precision and coverage do not produce the same ranking across approaches and should therefore be interpreted as complementary dimensions of threat-modelling performance.

This analysis primarily addresses RQ2.

4.6 STRIDE Category Analysis

To examine whether the evaluated approaches differed in their ability to identify threats across different security properties, the matched reference threats were analysed according to their STRIDE categories. The analysis uses the STRIDE classification assigned to the expert-vetted reference threat set. Because a reference threat may be associated with more than one STRIDE category, the category assignments are not mutually exclusive.

For each approach, STRIDE-specific reference-threat recall was calculated as the proportion of reference threats assigned to a given STRIDE category that received a valid Primary True Positive mapping. This measure therefore indicates coverage of the reference threats within each STRIDE category and should not be interpreted as classification accuracy or overall threat-model precision.

$$\text{STRIDE-Specific Recall} = \frac{\text{Matched Reference Threats in Category}}{\text{Reference Threats in Category}} \times 100 \quad (4.3)$$

The reference threat set contains 36 Spoofing threats, 27 Tampering threats, 3 Repudiation threats, 26 Information Disclosure threats, 10 Denial of Service (DoS) threats, and 14 Elevation of Privilege (EoP) threats. The different category sizes should therefore be considered when interpreting the results.

The results show substantial variation across STRIDE categories. ThreMoLIA achieved the highest reference-threat recall in five of the six categories and tied with

Table 4.4: STRIDE-Specific Reference-Threat Recall

Approach	Spoof.	Tamp.	Repud.	Info.	Disc.	DoS	EoP	Overall
OWASP Threat Dragon	16.67	14.81	0.00		19.23	70.00	0.00	19.39
Microsoft TMT	27.78	29.63	100.00		19.23	60.00	7.14	28.57
GPT-5.6	50.00	48.15	66.67		61.54	90.00	21.43	53.06
Llama 3 8B via Ollama	33.33	29.63	0.00		11.54	10.00	14.29	20.41
ThreMoLIA	83.33	70.37	100.00		61.54	100.00	42.86	70.41

Microsoft Threat Modeling Tool for the highest recall in Repudiation, where both approaches achieved 100.00%. ThreMoLIA showed particularly high recall for Spoofing (83.33%), DoS (100.00%), and Repudiation (100.00%). GPT-5.6 achieved comparatively strong coverage for DoS (90.00%) and Information Disclosure (61.54%).

Microsoft Threat Modeling Tool achieved complete recall for the three Repudiation reference threats, while its recall for the other categories was considerably lower. OWASP Threat Dragon showed relatively high recall for DoS threats (70.00%) but limited coverage for Spoofing, Tampering, Information Disclosure, and EoP. Llama 3 8B via Ollama showed moderate coverage for Spoofing and Tampering but lower coverage for Information Disclosure and DoS, and it did not identify any of the three Repudiation reference threats.

The category-level results indicate that threat coverage is not uniform across security properties. The differences should be interpreted as STRIDE-specific reference-threat recall under the evaluation procedure rather than as evidence that an approach is intrinsically more accurate for a particular security property. In particular, categories with small reference sets can produce large percentage differences from a small number of matched or unmatched threats. The three Repudiation reference threats provide a clear example of this effect.

Overall, the STRIDE analysis complements the aggregate reference-threat recall reported in Section 4.4 by showing where the approaches identified or missed threats within the expert-vetted reference threat set.

4.7 LLM-Specific Security Analysis

To examine reference threats associated with security concerns specific to LLM-integrated applications, the reference threats were additionally classified into LLM-specific and non-LLM-specific groups. This analysis is treated as a supporting analysis rather than as an independent research question.

The reference threat set contains 38 LLM-specific threats and 60 non-LLM-specific threats. For each approach, LLM-specific reference-threat recall was calculated as the number of LLM-specific reference threats receiving a Primary True Positive mapping divided by the 38 LLM-specific reference threats. The same calculation was applied to the 60 non-LLM-specific reference threats.

The results show that GPT-5.6 achieved the highest recall for LLM-specific reference threats at 65.79%, followed by ThreMoLIA at 63.16%. Microsoft TMT achieved 28.95%, while Llama 3 8B via Ollama and OWASP Threat Dragon achieved 21.05% and 10.53%, respectively. Thus, GPT-5.6 and ThreMoLIA identified a substantially larger proportion of the LLM-specific reference threats than the other evaluated ap-

Table 4.5: LLM-Specific and Non-LLM-Specific Reference-Threat Recall

Approach	LLM-Specific TP	LLM-Specific Recall (%)	Non-LLM TP	Non-LLM Recall (%)
OWASP Threat Dragon	4	10.53	15	25.00
Microsoft TMT	11	28.95	17	28.33
GPT-5.6	25	65.79	27	45.00
Llama 3 8B via Ollama	8	21.05	12	20.00
ThreMoLIA	24	63.16	45	75.00

proaches.

For the non-LLM-specific reference threats, ThreMoLIA achieved the highest recall at 75.00%, followed by GPT-5.6 at 45.00%. Microsoft TMT and OWASP Threat Dragon achieved 28.33% and 25.00%, respectively, while Llama 3 8B via Ollama achieved the lowest recall at 20.00%.

The difference between the LLM-specific and non-LLM-specific results indicates that the relative performance of the approaches varies according to the type of reference threat being considered. GPT-5.6 showed slightly higher recall for LLM-specific threats than for non-LLM-specific threats, whereas ThreMoLIA showed substantially higher recall for non-LLM-specific threats. These results provide supporting evidence about reference-threat coverage for security concerns associated with LLM-integrated systems.

The results should not be interpreted as framework-mapping accuracy, overall threat-modelling accuracy, or architectural grounding. In particular, LLM-specific recall measures identification of corresponding threats in the LLM-specific subset of the expert-vetted reference threat set. It does not establish whether a generated finding was correctly assigned to a particular LLM security taxonomy or category.

4.8 LLM Run Consistency Analysis

Run-to-run consistency was considered as a supporting methodological aspect for LLM-based approaches where records from multiple executions were available. The purpose of this analysis was to consider whether repeated executions of the same approach could produce identical or different threat-generation outputs.

Consistency can be assessed using set overlap between comparable executions. For two threat sets A and B , the Jaccard similarity can be expressed as:

$$J(A, B) = \frac{|A \cap B|}{|A \cup B|} \quad (4.4)$$

where A and B represent the threat sets generated in two comparable executions. A Jaccard value of 1 indicates identical sets, whereas lower values indicate less overlap between the compared sets.

Available records indicate that repeated executions of general-purpose LLM approaches can produce different threat-generation outputs under comparable conditions. This observation is relevant to the reproducibility of LLM-assisted threat modelling because output variation may occur even when the underlying scenario and threat-modelling requirements remain unchanged.

However, the available records do not provide a sufficiently complete and standardized run-level dataset to quantify this variation consistently across the evalu-

ated approaches. A complete quantitative run-consistency analysis is therefore not included in the final evaluation dataset used for the reported primary metrics. Consequently, specific aggregate Jaccard values and run-level finding counts are not used as formal quantitative comparison results in this thesis.

The consistency analysis is therefore treated as supporting methodological context rather than as a performance metric. Variation between executions does not by itself indicate lower quality, since a different execution may contain additional valid threats. Conversely, identical outputs do not establish correctness, completeness, or architectural grounding. Consistency must therefore be interpreted alongside reference-threat coverage, precision, false positives, false negatives, and duplicate findings.

4.9 Error Analysis

Additional analysis was performed on the available ThreMoLIA error reports to identify limitations reported during its automated threat-modelling process. This analysis is treated as supporting evidence rather than as an independent research question.

The available error information was examined according to the error types reported by the evaluated system, including:

- Categorization errors;
- Embedding errors;
- Severity estimation errors; and
- Framework mapping errors.

The reported error categories concern different aspects of the automated processing process. Categorization errors concern threat classification, embedding errors concern semantic representation or matching, severity estimation errors concern severity assessment, and framework mapping errors concern assignment to security frameworks.

The reported errors are analysed separately from the independently evaluated precision and reference-threat coverage measures. In particular, self-reported errors from the ThreMoLIA processing pipeline are not treated as direct measurements of false positives, false negatives, or overall threat-modelling performance.

False positives and false negatives are determined through the predefined comparison of generated findings against the expert-vetted reference threat set. The ThreMoLIA error reports instead describe issues reported within the tool’s own processing process.

The error analysis therefore provides supporting evidence concerning observed limitations in automated processing. The primary comparative evaluation remains based on the threat-matching, classification, and evidence-grounding procedures described in Chapter 3.

4.10 Summary of Results

The results show substantial differences between the five evaluated threat modelling approaches under the experimental conditions of the study. The approaches differed in raw finding volume, reference-threat coverage, precision, evidence grounding, STRIDE-specific recall, LLM-specific reference-threat recall, redundancy, and the available run-to-run consistency evidence.

Across the three scenarios, the approaches generated 1,025 raw findings: 123 from OWASP Threat Dragon, 301 from Microsoft Threat Modeling Tool (TMT), 181 from GPT-5.6, 92 from Llama 3 8B executed through Ollama, and 328 from ThreMoLIA.

The primary comparison was based on reference-threat coverage and precision, with evidence grounding examined as a separate analytical dimension. Coverage was evaluated against the 98-threat expert-vetted reference threat set, while precision was calculated from the final classification of generated findings into primary true positives and false positives, with duplicate findings retained as a separate analytical outcome. False negatives represent reference threats for which no valid primary mapping was established.

The aggregate results show that ThreMoLIA achieved the highest reference-threat recall (70.41%), followed by GPT-5.6 (53.06%). GPT-5.6 achieved the highest precision (47.71%), while ThreMoLIA achieved the highest F1-score (52.67%). Llama 3 8B executed through Ollama, OWASP Threat Dragon, and Microsoft TMT achieved lower aggregate recall, precision, and F1-scores under the same evaluation procedure. These results indicate different trade-offs between identifying reference threats and limiting non-matching findings.

The quantitative evidence-grounding assessment classified all 1,025 generated findings against the architectural evidence of their corresponding scenarios. Overall, 329 findings (32.10%) were classified as Fully Grounded, 689 (67.22%) as Partially Grounded, and 7 (0.68%) as Not Grounded; no findings were classified as Unassessable. GPT-5.6 achieved the highest full grounding rate (74.59%), followed by Llama 3 8B executed through Ollama (31.52%), ThreMoLIA (31.10%), Microsoft TMT (19.60%), and OWASP Threat Dragon (3.25%). These results characterize architectural support of generated findings and are interpreted separately from reference-threat matching.

The supporting analyses provided additional information about the characteristics of the generated findings. STRIDE-specific analysis showed differences in reference-threat recall across security categories, while the LLM-specific analysis showed comparatively high recall for GPT-5.6 and ThreMoLIA on LLM-specific reference threats. Redundancy also differed substantially between approaches; in particular, ThreMoLIA produced 164 duplicate findings among its 328 raw findings, illustrating that higher reference-threat coverage was accompanied by substantial repeated representations in the generated output.

Run-to-run consistency was considered as a supporting methodological analysis where multiple comparable executions were available. Because the available repeated-run data did not support a complete quantitative comparison across all approaches, Jaccard values were not treated as formal comparative performance measures.

Overall, the results demonstrate that raw finding volume alone is not an adequate

basis for comparing threat modelling approaches. Differences in reference-threat coverage, precision, false positives, false negatives, duplicates, evidence grounding, and supporting analyses must be considered together when interpreting the comparative results. The evidence-grounding assessment provides an additional architectural-evidence dimension rather than a measure of reference-threat correctness.

4.11 Exploratory Qualitative Industry Feedback

A supplementary exploratory practitioner assessment was conducted using two threat modelling reports generated for the same system scenario: one produced using GPT-5.6 and one using OWASP Threat Dragon. Qualitative feedback was provided by **Rickard Erwinson of Waibloz AB**. The assessment focused on the perceived clarity, relevance, actionability, real-world usefulness, and overall quality of the two reports.

The practitioner feedback described the OWASP Threat Dragon report as systematically organized and useful for considering broad security categories. The GPT-5.6 report was described as stronger in reasoning about specific application logic and architectural details.

These observations are treated as qualitative contextual evidence rather than as objective measurements of threat-modelling effectiveness. The feedback was not used to determine reference-threat mappings, coverage, precision, false positives, false negatives, or evidence grounding. These quantities were determined independently through the evaluation procedure described in Chapter 3.

The assessment involved one practitioner assessing two selected reports and therefore does not provide a basis for statistical generalization to the wider population of security practitioners. It was intended to provide an industry-oriented perspective on selected outputs rather than to constitute a formal usability evaluation. In particular, the assessment was not conducted using the System Usability Scale (SUS) or another validated usability instrument.

This chapter interprets the findings presented in Chapter 4 in relation to the research questions, methodological design, and characteristics of the five evaluated threat modelling approaches. The discussion focuses on the implications of the observed differences rather than repeating the results. Primary quantitative interpretation is based on reference-threat coverage and precision, with false positives, false negatives, and duplicate findings considered where relevant. STRIDE-specific recall, LLM-specific reference-threat recall, normalization, redundancy, run-to-run consistency, error analysis, and the evidence-grounding framework are considered as supporting evidence or methodological context where appropriate.

5.1 Research Questions Revisited

The study addressed three research questions concerning threat coverage, threat precision, and evidence grounding:

1. **RQ1:** How does the threat coverage of AI-based threat modelling approaches compare with classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios?
2. **RQ2:** How does the precision of threat findings generated by AI-based approaches compare with that of classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios?
3. **RQ3:** How can the evidence grounding of threat findings generated by AI-based and classical threat modelling approaches be characterized with respect to the architectural evidence of the analysed system scenarios?

The discussion below interprets the empirical findings in relation to the three research questions, with primary emphasis on reference-threat coverage and precision and supporting consideration of false positives, false negatives, redundancy, evidence grounding, and the other analyses where they contribute to interpretation.

RQ3 is addressed through the quantitative grounding assessment described in Chapter 3. All 1,025 generated findings were assessed against the architectural evidence of their corresponding scenarios using the predefined grounding rubric. The assessment is independent of reference-threat matching and therefore does not infer grounding from true-positive, duplicate, or false-positive classification.

The results show that 329 of the 1,025 findings (32.10%) were classified as Fully Grounded, while 689 (67.22%) were Partially Grounded and 7 (0.68%) were Not Grounded. No findings were classified as Unassessable. GPT-5.6 achieved the highest full grounding rate (74.59%), followed by Llama 3 8B executed through Ollama (31.52%), ThreMoLIA (31.10%), Microsoft TMT (19.60%), and OWASP Threat Dragon (3.25%). These results characterize the degree of architectural support in the generated findings and are not interpreted as measures of reference-threat correctness.

The grounding assessment was conducted as a single-pass quantitative coding analysis without an independent parallel assessor. The resulting grounding rates are therefore interpreted as descriptive measurements under the defined rubric rather than as independently validated inter-rater measurements.

Raw finding volume is not treated as a standalone measure of threat modelling effectiveness. Differences in output volume are instead interpreted in relation to the reference-threat baseline, evidence grounding, and the other evaluation measures.

5.2 Classical Tools Compared with LLM-Based Approaches

The results indicate that the evaluated classical and LLM-based approaches exhibit different threat-generation characteristics when applied to the selected LLM-integrated system scenarios.

The classical approaches, represented by OWASP Threat Dragon and Microsoft Threat Modeling Tool (TMT), provide structured and architecture-oriented threat modelling based on established security concepts and threat categories. Their outputs represent security concerns associated with the architectural elements and security properties represented in the scenarios.

The LLM-based approaches, represented by GPT-5.6, Llama 3 8B via Ollama, and ThreMoLIA, provide a different form of analysis based on natural-language interpretation and model-assisted reasoning over the provided scenarios. Their outputs can describe relationships between application components, user interactions, data flows, and LLM-related functionality at different levels of detail.

The approaches also differ substantially in the number of findings they produce. These differences should not be interpreted directly as differences in effectiveness because output volume is influenced by how an approach enumerates, decomposes, and represents security concerns. Reference-threat coverage and precision therefore provide a more informative quantitative basis for comparison than raw output volume. False positives, false negatives, and duplicate findings further characterize the relationship between generated findings and the expert-vetted reference threat set.

LLM-based approaches may introduce additional sources of output variability because their results can depend on the selected model, prompt, configuration, and execution conditions. The available consistency evidence is therefore considered as supporting methodological context rather than as a formal quantitative performance measure. Similarly, the error analysis provides additional context for limitations observed in the ThreMoLIA processing pipeline.

The approaches should therefore be understood as exhibiting different threat-

generation characteristics rather than being ranked solely according to the number of findings produced. Their relative strengths and limitations are interpreted primarily using reference-threat coverage, precision, false positives, false negatives, and duplicate findings, with the supporting analyses providing additional context. Evidence grounding is discussed separately because it represents architectural evidence support rather than reference-threat matching.

5.3 Interpretation of Threat Generation Results

The five approaches produced substantially different numbers of threat findings. Across the three scenarios, OWASP Threat Dragon generated 123 findings, Microsoft Threat Modeling Tool (TMT) generated 301, GPT-5.6 generated 181, Llama 3 8B via Ollama generated 92, and ThreMoLIA generated 328. These differences should not be interpreted as direct measures of effectiveness, since a larger output may contain repeated or irrelevant findings.

The differences are partly related to how the approaches represent and explore the system architecture. Classical tools rely on structured threat-modelling processes, while the evaluated AI-based approaches generate threats from architectural descriptions using language-model reasoning. ThreMoLIA applies a systematic STRIDE-oriented analysis across the represented architecture. This supports broad exploration of potential threats, but it can also produce multiple findings describing the same underlying security condition. This is reflected in its 164 duplicate findings, corresponding to 50% of its total output. The duplicate analysis identified several cases of *data-flow redundancy*, where the same vulnerability mechanism was reported for adjacent micro-flow segments.

GPT-5.6 produced considerably fewer duplicate findings relative to its total output. Its generated output contained relatively fewer repeated representations of the same security concern, with related architectural elements more often represented within the same threat description. This observed output characteristic is consistent with a more selective form of threat formulation, although the evaluation does not establish the internal reasoning process responsible for it. This is consistent with its lower redundancy, although the evaluation does not establish that GPT-5.6 performs explicit internal deduplication.

Overall, the results indicate a trade-off between **systematic threat-space exploration and output conciseness**. ThreMoLIA’s systematic processing favoured broader exploration but increased redundancy, whereas GPT-5.6 generated a more selective set of findings. Therefore, the usefulness of threat-generation output cannot be assessed from output volume alone; the relationship between coverage, precision, false positives, and redundancy must also be considered.

5.4 Discussion of RQ1: Threat Coverage

RQ1 asks: *How does the threat coverage of AI-based approaches compare with classical threat modelling tools?*

The evaluated approaches identified substantially different portions of the expert-vetted reference baseline. ThreMoLIA achieved the highest reference-threat recall (70.41%), followed by GPT-5.6 (53.06%). The remaining approaches achieved considerably lower recall, with Microsoft TMT at 28.57%, Llama 3 8B via Ollama at 20.41%, and OWASP Threat Dragon at 19.39%.

The higher coverage of ThreMoLIA is consistent with its systematic STRIDE-oriented analysis. Examining the architecture through multiple threat categories provides more opportunities to identify threats corresponding to different architectural elements. The same systematic behaviour can, however, produce multiple findings describing the same underlying security condition, as reflected in the redundancy observed in Section 5.3.

5.5 Discussion of RQ2: Threat Precision

RQ2 asks: *How does the precision of threat findings generated by AI-based approaches compare with those generated by classical threat modelling approaches?*

Precision provides a complementary perspective to reference-threat coverage, as identifying more reference threats may also introduce false positives or redundant findings. Under the primary-match precision definition, GPT-5.6 achieved the highest precision at 47.71%, followed by ThreMoLIA at 42.07%, Llama 3 8B via Ollama at 30.30%, OWASP Threat Dragon at 19.39%, and Microsoft Threat Modeling Tool at 11.24%.

GPT-5.6 generated 181 findings, comprising 52 primary true positives, 57 false positives, and 72 duplicates, while ThreMoLIA generated 328 findings, comprising 69 primary true positives, 95 false positives, and 164 duplicates. Because duplicates are excluded from the precision denominator, GPT-5.6's higher precision indicates a higher proportion of primary matches among findings included in the precision calculation, not greater reference-threat coverage. The complementary primary-match yield was 28.73% for GPT-5.6 and 21.04% for ThreMoLIA, contextualizing primary matches against the complete raw output and showing the effect of duplicate findings. In particular, ThreMoLIA's 42.07% precision compared with its 21.04% yield reflects the substantial redundancy in its output.

ThreMoLIA nevertheless achieved the highest reference-threat recall at 70.41%, compared with 53.06% for GPT-5.6, and the highest F1-score at 52.67%, narrowly exceeding GPT-5.6 at 50.24%. The F1-score reflects the combined behaviour of precision and recall under the defined evaluation procedure and is not a direct measure of practical usefulness or analyst efficiency. Rather, ThreMoLIA's higher F1-score results from its substantially higher recall compensating for its lower precision under the harmonic-mean formulation.

The results therefore demonstrate a coverage-precision trade-off. GPT-5.6 produced a smaller output with higher primary-match precision and yield, whereas ThreMoLIA identified more reference threats but produced more duplicate and false-

positive findings. Broader threat discovery may therefore increase the threats available for subsequent review while also increasing the need for consolidation and filtering. The classical approaches also showed lower primary-match precision: Microsoft Threat Modeling Tool generated 301 findings, including 28 primary true positives and 221 false positives, while OWASP Threat Dragon generated 123 findings, including 19 primary true positives and 79 false positives. Thus, structured or architecture-oriented threat modelling does not by itself guarantee high precision relative to the expert-vetted reference baseline, consistent with empirical threat-modelling research distinguishing correctness, false positives, and completeness [17].

These results should be interpreted within the experimental design, as differences may reflect modelling mechanisms, representations, prompting, or execution conditions rather than a single underlying factor. Moreover, correspondence with the expert-vetted reference baseline does not establish that a finding represents a confirmed real-world vulnerability, while a non-matching finding is not necessarily an invalid security concern. **RQ2 is therefore answered by showing a clear coverage–precision trade-off:** GPT-5.6 achieved the highest primary-match precision and yield, whereas ThreMoLIA achieved the highest recall and F1-score. The evaluated approaches consequently exhibit different strengths rather than a universally superior approach, supporting multidimensional evaluation using coverage, precision, false positives, false negatives, and redundancy rather than raw finding volume alone.

5.6 Discussion of RQ3: Evidence Grounding

RQ3 examined how the evidence grounding of generated threat findings can be characterized with respect to the architectural evidence of the analysed scenarios.

The quantitative grounding assessment shows substantial differences between the evaluated approaches. Overall, 329 of the 1,025 generated findings (32.10%) were classified as Fully Grounded, while 689 (67.22%) were classified as Partially Grounded and 7 (0.68%) as Not Grounded. GPT-5.6 achieved the highest full grounding rate at 74.59%, substantially exceeding Llama 3 8B executed through Ollama (31.52%), ThreMoLIA (31.10%), Microsoft TMT (19.60%), and OWASP Threat Dragon (3.25%).

The higher full grounding rate observed for GPT-5.6 indicates that a larger proportion of its generated findings could be connected to explicit architectural evidence while also receiving sufficient support for the claimed threat mechanism and security consequence under the defined rubric. This result should not, however, be interpreted as evidence that GPT-5.6 generated the most correct threat model overall. Grounding and reference-threat matching measure different properties. A finding can be fully grounded in the architecture while still being classified as a false positive because the corresponding security concern is not represented in the expert-vetted reference threat set.

The substantial proportion of Partially Grounded findings across the evaluated approaches also indicates that architectural association alone does not necessarily provide complete support for a generated threat claim. Partial grounding may arise when the relevant architectural context is identifiable but the claimed mechanism de-

depends on implementation details, configuration, infrastructure, or capabilities that are not explicitly represented in the scenario architecture. This distinction is particularly relevant when interpreting AI-generated threat findings, since plausible security mechanisms may extend beyond what can be established from the specified architecture.

The grounding results therefore complement, rather than replace, the reference-threat coverage and precision results. ThreMoLIA achieved the highest reference-threat recall, whereas GPT-5.6 achieved the highest full grounding rate and primary-match precision. These differences demonstrate that identifying reference threats, producing non-matching findings, and providing architectural support for generated claims are distinct dimensions of threat-modelling output quality.

The grounding assessment was conducted as a single-pass quantitative coding analysis without an independent parallel assessor. The results should therefore be interpreted as descriptive measurements under the defined grounding rubric rather than as independently validated inter-rater measurements. Nevertheless, the assessment provides a systematic architectural-evidence dimension that complements the reference-threat matching analysis and enables RQ3 to be evaluated quantitatively under the defined experimental conditions.

5.7 Reliability and Validity Considerations

The validity and reliability of the findings are supported by preserving the original experimental outputs, documenting the analytical procedures, and maintaining traceability between generated findings, scenario architectures, the expert-vetted reference threat set, and the reported evaluation results.

The use of the same three underlying system scenarios across the five evaluated approaches provides a common basis for comparison. The predefined reference threat set and evaluation criteria further provide a consistent basis for analysing reference-threat coverage and precision across the generated threat sets.

Several limitations nevertheless affect the interpretation of the findings.

First, the classification of generated findings involved explicit matching criteria, architectural evidence, confidence assessment, and adjudication of low-confidence cases. The final adjudication review covered 27 low-confidence Primary True Positive cases, of which 20 were retained as true positives and 7 were classified as requiring a change to the reference mapping. No reviewed case was changed to a false positive. This process was used to improve consistency in the final matching decisions. A formal inter-rater reliability statistic such as Cohen's kappa was not calculated because independently coded datasets prior to adjudication were not retained as a basis for such a calculation.

Second, the expert-vetted reference threat set constitutes a reviewed comparison baseline rather than exhaustive ground truth. The final baseline contains 98 reference threats across the three scenarios. A generated threat that is absent from this baseline is therefore not necessarily invalid, while a matching reference threat does not by itself establish that the generated finding is fully correct or independently verified. Coverage and precision should consequently be interpreted as measurements relative to the defined reference baseline and matching procedure.

Third, architectural binding and evidence grounding are distinguished from reference-threat matching and threat validity. A separate per-finding grounding assessment was conducted for all 1,025 generated findings using the preserved original outputs and the corresponding scenario architectures. The assessment classified findings as Fully Grounded, Partially Grounded, Not Grounded, or Unassessable according to the predefined grounding rubric. The resulting grounding rates therefore provide a quantitative characterization of architectural evidence support rather than a measure of reference-threat correctness.

The grounding assessment was conducted as a single-pass coding analysis without an independent parallel assessor. Consequently, the reported grounding classifications and rates should be interpreted as descriptive measurements under the defined rubric rather than as independently validated inter-rater measurements. This limitation does not alter the reported reference-threat matching classifications because the grounding assessment was conducted independently of the TP, duplicate, and FP decisions.

Fourth, LLM-generated outputs may vary depending on model version, prompt formulation, configuration, and execution conditions. The available consistency evidence provides supporting methodological context concerning variation in recorded repeated executions, but it does not establish that the same behaviour will occur in future executions or with different model versions. The reported results therefore describe the outputs produced under the documented experimental conditions.

These considerations mean that the results should be interpreted as an empirical comparison of the evaluated approaches under the defined experimental conditions. They do not establish a universal ranking of threat modelling effectiveness, nor do they demonstrate that any evaluated approach can independently provide complete security assurance.

5.8 Practical Implications

The findings have implications for practitioners conducting security analysis of LLM-integrated software systems.

Classical threat modelling approaches remain relevant because they provide structured architectural representations, established security taxonomies, and systematic mechanisms for relating security concerns to system elements and interactions. The results indicate that these characteristics remain useful as a foundation for architecture-oriented security analysis.

LLM-based approaches provide an additional mechanism for interpreting natural-language system descriptions and generating contextual security findings. The observed differences in reference-threat coverage and precision indicate that generated findings should be treated as security-analysis evidence requiring validation rather than as automatically confirmed threats.

A practical workflow can therefore combine structured threat modelling with LLM-assisted analysis. The system architecture should be represented explicitly, including relevant components, data flows, trust boundaries, assets, and security requirements. Architecture-oriented threat modelling can provide a structured security basis, while LLM-based approaches can be used as an additional source of

threat discovery and contextual reasoning. Generated findings should subsequently be checked against the actual architecture, security requirements, and established security criteria before being treated as actionable security findings.

Maintaining traceability is particularly important when using LLM-generated threats. Findings should be associated with the architectural evidence that supports their applicability where such evidence is available, while equivalent findings may be consolidated for analytical purposes without discarding the original outputs required for traceability.

The results therefore support LLM-assisted threat modelling as a complementary activity within a human-supervised security engineering process rather than as an automatic replacement for established threat modelling practices. The appropriate combination of approaches depends on the architecture, security objectives, evaluation requirements, and required level of assurance.

5.9 Ethical and Societal Considerations

The use of LLM-based threat modelling introduces considerations related to trust, accountability, transparency, and the delegation of security analysis to automated systems.

Security decisions based solely on automatically generated recommendations may introduce risks when findings are inaccurate, incomplete, redundant, or insufficiently supported by the analysed system architecture. LLM-generated threat information should therefore be treated as analytical assistance rather than as an authoritative security assessment.

Human judgement remains important when interpreting, validating, and acting upon AI-assisted security analysis. Generated findings should be evaluated against the actual system architecture, security requirements, and applicable security practices before they inform security decisions.

The use of LLMs also raises accountability concerns. Responsibility for a security decision cannot be delegated to the model when an automated system produces an incorrect or misleading assessment. Practitioners and organizations using AI-assisted threat modelling therefore remain responsible for validating generated findings and determining their suitability for the intended security context.

Transparency about the model, configuration, input information, and evaluation process is also important when AI-assisted analysis contributes to security decisions. Such information can help practitioners understand the scope and limitations of generated findings and support appropriate human review.

AI-assisted threat modelling may provide additional perspectives during the identification of security concerns in LLM-integrated systems. However, the results of this study do not establish that an LLM-based approach guarantees improved security or complete threat identification. Its usefulness depends on the quality of the system information provided, the model and configuration used, the generated output, and the subsequent human validation process.

5.10 Discussion Summary

The discussion examined the differences between classical and LLM-based threat modelling approaches in relation to reference-threat coverage, precision, evidence grounding, and the supporting analytical dimensions considered in this study.

The evaluated approaches exhibited different threat-generation characteristics. Classical approaches provided structured and architecture-oriented threat modelling through established modelling processes and security classifications, while the LLM-based approaches provided additional mechanisms for interpreting natural-language system descriptions and generating contextual security findings.

The findings demonstrate the importance of evaluating generated threat sets using multiple criteria rather than relying solely on the number of generated findings. Reference-threat coverage and precision capture different properties of the generated outputs, while false positives, false negatives, and duplicate findings provide additional information about the composition of the generated threat sets. Evidence grounding provides a separate architectural-evidence dimension, while supporting analyses concerning STRIDE categories, LLM-specific reference-threat recall, normalization and redundancy, run-to-run consistency, and processing errors provide further context for interpreting the results.

The results also demonstrate that the evaluation dimensions should not be treated as interchangeable. A finding may be associated with an architectural element without necessarily corresponding to a reference threat, while a finding may represent a plausible security concern without providing sufficient architectural evidence to establish its applicability. Similarly, consistency across repeated LLM executions does not establish correctness. Evidence grounding is therefore evaluated separately from reference-threat matching because architectural support and correspondence with the expert-vetted reference threat set represent distinct properties.

Taken together, the findings support treating LLM-based threat modelling as a complementary security analysis activity rather than as an automatic replacement for structured threat modelling approaches. LLM-generated findings can provide additional security information and contextual perspectives, but their practical use requires validation against the system architecture, security requirements, and defined evaluation criteria.

The conclusions of this study are bounded by the three evaluated scenarios, the five evaluated approaches, the 98-threat expert-vetted reference threat set, the defined evaluation criteria, and the experimental conditions described in the methodology. The results should therefore be interpreted as empirical observations under the specified conditions rather than as universal claims about the effectiveness of classical or LLM-based threat modelling.

5.11 Implications for Security Practitioners

The findings of this study have implications for practitioners responsible for designing, analysing, and securing LLM-integrated systems.

The evaluated classical threat modelling approaches provide structured and architecture-oriented security analysis through established threat modelling methodologies and

security classifications. These characteristics are useful for maintaining a systematic representation of system components, interactions, data flows, and security properties during security analysis.

The evaluated LLM-based approaches provide an additional mechanism for interpreting natural-language system descriptions and generating contextual security findings. The empirical results nevertheless show that the approaches differ in reference-threat coverage, precision, and evidence grounding. Consequently, LLM-generated findings should be treated as inputs to security analysis that require validation against the actual architecture and applicable security requirements.

From a practical perspective, security teams can use LLM-based approaches as an additional threat-discovery activity during system design and security review. Generated findings should subsequently be evaluated for correspondence with relevant security concerns and for sufficient architectural support before being treated as confirmed security findings. Structured threat modelling can provide an architectural basis against which additional AI-generated findings can be reviewed.

The supplementary feedback from Rickard Erwinson of Waibloz AB provides a limited practitioner perspective on two selected reports. The feedback favoured the GPT-5.6 report in terms of clarity, relevance, actionability, and overall perceived quality, while identifying value in the structured organization and security categorization of the OWASP Threat Dragon report. These observations are contextual and are not treated as generalizable evidence of practitioner preference or as validation of the quantitative results.

These findings support a human-supervised workflow in which LLM-based analysis is used as complementary threat-discovery evidence and generated findings are subsequently reviewed against the system architecture and security requirements. The appropriate role of each approach therefore depends on the required coverage, precision, assurance level, and review capacity.

5.11.1 Feature Completeness

The audited feature matrix provides a supplementary qualitative comparison of the documented capabilities of the evaluated approaches. The matrix considers whether selected threat-modelling capabilities are documented for each approach, but these capability observations are not treated as measures of empirical threat-modelling effectiveness.

The feature comparison is therefore kept separate from the quantitative evaluation of reference-threat coverage, precision, recall, and F1-score. Evidence grounding is likewise not used as a numerical feature-completeness criterion because grounding measures architectural evidence support rather than documented tool capability.

Chapter 6

Conclusions and Future Work

This chapter concludes the thesis by summarizing the main findings, answering the research questions, discussing the contributions of the study, and presenting directions for future research.

The objective of this thesis was to empirically compare classical and LLM-based threat modelling approaches when analysing LLM-integrated software systems. The study evaluated OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B via Ollama, and ThreMoLIA across three structured LLM-integrated system scenarios.

The study was motivated by the increasing integration of large language models into software systems and by the security considerations introduced through interactions between users, application components, contextual information, data stores, and LLM functionality. The research investigated whether different threat modelling approaches identify different portions of the relevant threat space, whether their generated findings differ in precision, and how evidence grounding can be characterized in relation to the system architecture.

6.1 Conclusions

This thesis conducted a comparative empirical evaluation of five threat modelling approaches across three structured LLM-integrated system scenarios. The final experimental dataset contained 1,025 raw findings across the five approaches. ThreMoLIA contributed 328 findings, consisting of 106 findings for Scenario 1, 105 findings for Scenario 2, and 117 findings for Scenario 3.

The evaluation considered threat coverage and threat precision as the primary quantitative comparison dimensions, while evidence grounding was examined as an additional analytical dimension. These dimensions provide complementary perspectives on the generated threat sets and prevent raw finding volume from being interpreted as a standalone measure of threat modelling effectiveness.

6.1.1 Conclusion for RQ1: Threat Coverage

RQ1 examined how the threat coverage of AI-based threat modelling approaches compares with classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios.

The results show that ThreMoLIA achieved the highest aggregate recall against the 98-threat expert-vetted reference baseline, identifying 69 of the 98 reference

threats (70.41%). GPT-5.6 identified 52 of 98 reference threats (53.06%), followed by Microsoft TMT with 28 of 98 (28.57%), Llama 3 8B via Ollama with 20 of 98 (20.41%), and OWASP Threat Dragon with 19 of 98 (19.39%).

These results indicate that the evaluated approaches identified substantially different portions of the expert-vetted reference baseline. ThreMoLIA provided the broadest reference-threat coverage in the evaluated dataset, while GPT-5.6 achieved the second-highest coverage. The results also demonstrate that higher raw output volume does not necessarily correspond directly to higher threat coverage, since duplicate and unmatched findings can contribute substantially to a generated output set.

The results therefore answer RQ1 by showing that the evaluated approaches differ substantially in their ability to identify threats represented in the expert-vetted reference baseline. No evaluated approach identified the complete 98-threat baseline.

6.1.2 Conclusion for RQ2: Threat Precision

RQ2 examined how the precision of threat findings generated by AI-based approaches compares with that of classical threat modelling approaches when applied to the same structured LLM-integrated system scenarios.

Under the defined one-to-one reference-matching procedure, GPT-5.6 achieved the highest aggregate precision at 47.71%, followed by ThreMoLIA at 42.07%, Llama 3 8B via Ollama at 30.30%, OWASP Threat Dragon at 19.39%, and Microsoft TMT at 11.24%. The corresponding aggregate F1-scores were 52.67% for ThreMoLIA, 50.24% for GPT-5.6, 24.39% for Llama 3 8B via Ollama, 19.39% for OWASP Threat Dragon, and 16.14% for Microsoft TMT.

These results demonstrate that coverage and precision capture distinct characteristics of threat generation. ThreMoLIA achieved the highest recall at 70.41% and the highest F1-score at 52.67%, while GPT-5.6 achieved the highest precision at 47.71% with a recall of 53.06%. Thus, ThreMoLIA identified a larger proportion of the expert-vetted reference threat set, whereas GPT-5.6 produced the highest proportion of primary reference-threat matches among its non-duplicate findings.

The results therefore answer RQ2 by demonstrating that the evaluated approaches exhibit different trade-offs between reference-threat coverage and precision. The findings also reinforce the importance of distinguishing primary true-positive matches from false positives and duplicate findings. Duplicates were not allowed to increase recall and therefore did not inflate the coverage results.

The precision values should be interpreted relative to the expert-vetted reference baseline and the defined matching procedure. They do not represent independent proof that a generated threat is a confirmed vulnerability.

6.1.3 Conclusion for RQ3: Evidence Grounding

RQ3 examined how the evidence grounding of generated threat findings can be characterized with respect to the architectural evidence of the analysed scenarios. The quantitative grounding assessment classified all 1,025 generated findings according to their architectural support. Overall, 329 findings (32.10%) were classified as Fully

Grounded, 689 (67.22%) as Partially Grounded, and 7 (0.68%) as Not Grounded, with no findings classified as Unassessable.

GPT-5.6 achieved the highest full grounding rate (74.59%), followed by Llama 3 8B executed through Ollama (31.52%), ThreMoLIA (31.10%), Microsoft TMT (19.60%), and OWASP Threat Dragon (3.25%). These results indicate that the evaluated approaches differed substantially in the extent to which their generated findings were supported by the architectural evidence of the analysed scenarios.

The grounding results are interpreted separately from reference-threat matching because architectural support does not establish reference-threat correctness. The grounding assessment was conducted as a single-pass coding analysis without an independent parallel assessor; therefore, the reported rates are descriptive measurements under the defined rubric rather than independently validated inter-rater measurements.

6.1.4 Overall Conclusion

Taken together, the findings demonstrate that classical and LLM-based threat modelling approaches exhibit different threat-generation characteristics rather than producing interchangeable results. The classical approaches use structured, architecture-oriented workflows, whereas the evaluated LLM-based approaches support natural-language analysis and contextual threat discovery within the experimental setting. The results therefore cannot be adequately characterized by raw finding counts alone.

The final aggregate comparison against the 98-threat expert-vetted reference baseline is presented in Table 6.1. The table reports raw generated findings, Primary True Positives, duplicate findings, false positives, false negatives, precision, recall, and F1-score.

Table 6.1: Final Comparative Evaluation Against the 98-Threat Expert-Vetted Reference Baseline

Approach	Reference	Raw	TP	Dup.	FP	FN	Precision	Recall	F1
ThreMoLIA	98	328	69	164	95	29	42.07	70.41	52.67
GPT-5.6	98	181	52	72	57	46	47.71	53.06	50.24
Llama 3 8B via Ollama	98	92	20	26	46	78	30.30	20.41	24.39
Microsoft TMT	98	301	28	52	221	70	11.24	28.57	16.14
OWASP Threat Dragon	98	123	19	25	79	79	19.39	19.39	19.39

Note: TP denotes Primary True Positives. Each reference threat can contribute at most one Primary True Positive within an approach and scenario; additional equivalent findings are classified as duplicates and do not increase recall. FN represents reference-threat instances for which no valid Primary True Positive mapping was established. Precision and recall are therefore interpreted relative to the 98-threat expert-vetted reference baseline.

No single approach dominated every evaluation dimension. ThreMoLIA achieved the highest reference-threat recall at 70.41% and the highest F1-score at 52.67%, whereas GPT-5.6 achieved the highest primary-match precision at 47.71% and the second-highest recall at 53.06%. ThreMoLIA’s higher recall was accompanied by 164 duplicate findings and 95 false positives, while GPT-5.6 produced fewer raw findings,

duplicates, and false positives but identified fewer reference threats. Primary-match yield further illustrates the effect of redundancy: GPT-5.6 achieved 28.73%, compared with 21.04% for ThreMoLIA.

Among the remaining approaches, Llama 3 8B via Ollama achieved 30.30% precision and 20.41% recall, Microsoft TMT achieved 28.57% recall with 11.24% precision, and OWASP Threat Dragon achieved 19.39% for precision, recall, and F1-score. These results demonstrate that raw output volume does not directly determine comparative performance, as larger outputs may contain both additional reference-threat matches and substantial redundancy or unmatched findings.

The quantitative evidence-grounding assessment provides an additional architectural-evidence dimension. Across all approaches, 329 of the 1,025 generated findings (32.10%) were classified as Fully Grounded, 689 (67.22%) as Partially Grounded, and 7 (0.68%) as Not Grounded. GPT-5.6 achieved the highest full grounding rate at 74.59%, followed by Llama 3 8B via Ollama at 31.52%, ThreMoLIA at 31.10%, Microsoft TMT at 19.60%, and OWASP Threat Dragon at 3.25%.

Evidence grounding is distinct from reference-threat matching. A finding may be fully grounded in the architecture while remaining a false positive relative to the expert-vetted reference baseline, while correspondence with a reference threat does not by itself establish full architectural grounding. The grounding results therefore complement, rather than replace, precision, recall, and F1-score.

Secondary analyses concerning STRIDE-specific recall, LLM-specific recall, redundancy, run-to-run consistency, and observed processing errors provide additional context but do not replace the primary precision, reference-threat coverage, or evidence-grounding measures.

Overall, the results support a complementary rather than universal ranking of threat-modelling approaches. ThreMoLIA provided the broadest reference-threat coverage, while GPT-5.6 provided the highest primary-match precision and full grounding rate. The findings therefore indicate that reference-threat coverage, precision, redundancy, and architectural evidence support represent distinct properties of threat-modelling outputs.

For threat-modelling research, the findings support multidimensional evaluation against a common expert-vetted reference baseline and explicit architectural evidence criteria. For practice, they suggest that AI-based threat modelling is most defensibly viewed as complementary security-analysis support whose outputs require architectural and expert review rather than as an autonomous replacement for established threat-modelling processes.

The conclusions are bounded by the three evaluated scenarios, five evaluated approaches, the 98-threat expert-vetted reference baseline, the documented model and tool configurations, and the evaluation procedures used in the experiment. The grounding assessment was conducted as a single-pass coding analysis without an independent parallel assessor; consequently, its results should be interpreted as descriptive measurements under the defined rubric rather than as independently validated inter-rater measurements.

Scope of inference. The findings do not establish that any evaluated approach is universally superior, that generated threats represent confirmed vulnerabilities, or that the observed differences are attributable solely to the underlying model or threat-modelling methodology. The study also does not establish that LLM-based approaches can independently replace human security expertise.

6.2 Contribution of the Thesis

This thesis makes three primary scientific contributions to the empirical study of threat modelling for LLM-integrated software systems.

6.2.1 A Multidimensional Empirical Evaluation Framework

The first contribution is an empirical evaluation framework for comparing different threat modelling approaches under a common experimental setting. The study applies five approaches - OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B executed through Ollama, and ThreMoLIA - to the same three predefined LLM-integrated system scenarios. The generated findings are evaluated against a common 98-threat expert-vetted reference baseline using explicit threat-mapping criteria.

The evaluation separates reference-threat coverage, primary-match precision, duplicate findings, false positives, and false negatives rather than treating raw finding volume as a direct measure of effectiveness. This provides a structured basis for comparing classical, general-purpose LLM-based, and LLM-assisted threat modelling approaches under the same scenario conditions.

6.2.2 Empirical Characterization of Coverage, Precision, and Redundancy

The second contribution is the empirical characterization of how different threat modelling approaches trade off reference-threat coverage, precision, and redundancy. The results demonstrate that substantially different threat-output profiles can arise from different approaches and that a larger number of generated findings does not necessarily correspond to greater reference-threat coverage or higher precision.

ThreMoLIA achieved the highest reference-threat recall at 70.41% and the highest F1-score at 52.67%, while GPT-5.6 achieved the highest primary-match precision at 47.71%. ThreMoLIA also produced 164 duplicate findings among its 328 generated findings, illustrating that broader threat exploration can be accompanied by substantial redundancy. GPT-5.6 generated fewer findings and fewer duplicate findings while achieving higher primary-match precision. These results demonstrate that threat-modelling output is better characterized using multiple complementary measures than by raw output volume alone.

6.2.3 Evidence Grounding as a Distinct Methodological Dimension

The third contribution is the methodological treatment of evidence grounding as a distinct evaluation dimension in threat modelling. The thesis distinguishes between a generated finding corresponding to an expert-vetted reference threat and that finding being supported by concrete architectural evidence.

Evidence grounding is defined in relation to architectural elements such as components, data flows, trust boundaries, assets, and security requirements where applicable, together with support for the claimed attack mechanism and security consequence. The thesis operationalizes this distinction through a per-finding grounding assessment of all 1,025 generated findings, classified as Fully Grounded, Partially Grounded, Not Grounded, or Unassessable. The assessment provides a quantitative characterization of architectural evidence support while remaining independent of the reference-threat matching classification.

The results show that 329 findings (32.10%) were Fully Grounded, 689 (67.22%) were Partially Grounded, and 7 (0.68%) were Not Grounded, with no findings classified as Unassessable. GPT-5.6 achieved the highest full grounding rate (74.59%), followed by Llama 3 8B via Ollama (31.52%), ThreMoLIA (31.10%), Microsoft TMT (19.60%), and OWASP Threat Dragon (3.25%). These results demonstrate the value of treating architectural evidence support as a separate dimension rather than inferring it from reference-threat matching alone.

The grounding assessment was conducted as a single-pass coding analysis without an independent parallel assessor. The reported grounding rates should therefore be interpreted as descriptive measurements under the defined rubric rather than as independently validated inter-rater measurements.

Taken together, these contributions support a multidimensional view of threat modelling effectiveness for LLM-integrated software systems. The contribution of the thesis is therefore not the identification of one universally superior approach, but the empirical characterization of differences in reference-threat coverage, precision, redundancy, and architectural evidence support under the defined experimental conditions.

6.3 Placing the Thesis in Perspective

The increasing integration of large language models into software systems creates additional considerations for software security and threat modelling. LLM-integrated applications combine conventional software components with model-based processing and natural-language interactions, which can introduce security concerns that need to be considered alongside traditional application threats.

From this perspective, the findings of this thesis indicate that threat modelling for LLM-integrated systems can benefit from considering both structured architecture-based analysis and LLM-assisted threat generation. The evaluated approaches exhibited different characteristics in threat identification, classification, reference-threat coverage, precision, and architectural association. Consequently, no single output characteristic is sufficient to describe the comparative performance of a threat mod-

elling approach.

The results further indicate that LLM-based approaches can be used as complementary sources of threat hypotheses rather than being treated as automatic replacements for established threat modelling approaches. LLM-generated findings can provide contextual descriptions and additional security perspectives, while structured threat modelling and human validation remain important for determining architectural applicability and security relevance.

This perspective is consistent with the empirical findings of the study. Thre-MoLIA achieved the highest aggregate reference-threat recall at 70.41% and the highest F1-score at 52.67%, while GPT-5.6 achieved the highest aggregate precision at 47.71% and the second-highest recall at 53.06%. Llama 3 8B via Ollama achieved 30.30% precision but substantially lower reference-threat recall at 20.41%. These differences demonstrate that reference-threat coverage and precision represent distinct properties of threat modelling outputs, while architectural association and evidence grounding require separate assessment.

The broader contribution of the thesis is therefore not the identification of a single universally superior approach, but the demonstration that different approaches provide different forms of threat information. Their usefulness should consequently be evaluated according to the security objective, system architecture, and validation requirements of the intended threat modelling process.

6.4 Limitations

Several limitations should be considered when interpreting the findings of this thesis.

First, the evaluation was conducted using three predefined LLM-integrated system scenarios. Although these scenarios provide a common basis for comparison, they cannot represent the full range of LLM-integrated applications, architectural patterns, domains, or deployment environments. The findings should therefore be interpreted within the scope of the selected scenarios.

Second, threat mappings, precision, and architectural evidence involved manual analytical judgement according to the documented evaluation procedure. Formal inter-rater reliability measures such as Cohen’s kappa could not be calculated because no independent parallel classifications with retained independent labels were available. Matching and adjudication rules were used to structure the classification process, but analytical judgement may nevertheless have influenced some decisions.

Third, the 98-threat expert-vetted reference baseline constitutes a comparison baseline rather than exhaustive ground truth. It contains 32 threats for Scenario 1, 33 for Scenario 2, and 33 for Scenario 3. A generated finding absent from the baseline is therefore not necessarily an invalid security concern, while a matching finding does not automatically establish complete correctness. Coverage and precision should consequently be interpreted relative to the defined baseline and evaluation procedure.

Fourth, the evidence-grounding assessment was conducted for all 1,025 generated findings using the preserved original outputs and the corresponding scenario architectures. The assessment provides a quantitative characterization of architectural evidence support, but it was performed as a single-pass coding analysis without an independent parallel assessor. Consequently, the grounding classifications and re-

sulting grounding rates should be interpreted as descriptive measurements under the defined rubric rather than as independently validated inter-rater measurements.

Fifth, LLM-generated outputs may vary with model version, prompt formulation, configuration, execution environment, and runtime conditions. The reported results therefore describe the outputs obtained under the documented experimental conditions. Available consistency evidence does not establish that identical outputs would be obtained in future executions.

Finally, the study evaluates threat modelling outputs rather than complete security outcomes. It does not measure the effectiveness of implemented security controls, security incidents, post-deployment security outcomes, or the ability of the evaluated approaches to prevent attacks in operational environments.

The practitioner feedback also has limited scope. It was provided by one practitioner, Rickard Erwinson of Waibloz AB, and concerned two selected reports. It therefore provides contextual qualitative evidence rather than generalizable evidence about practitioner preferences or industry practice. The feedback did not independently determine threat mappings or validate the quantitative evaluation results.

These limitations define the conditions under which the findings should be interpreted and identify areas for future research.

6.5 Future Work

The findings of this thesis provide several directions for future research.

First, larger-scale evaluations involving additional LLM-integrated architectures, application domains, and industrial case studies could provide stronger evidence regarding the generalizability of the findings. Broader and independently reviewed reference-threat baselines could also provide a stronger basis for evaluating coverage and precision.

Second, future research could strengthen the evidence-grounding assessment through independently performed parallel coding by multiple assessors. Inter-rater agreement could then be quantified, while the grounding rubric could be further refined through additional architectural cases and adjudicated examples. This would provide stronger evidence regarding the reliability and reproducibility of the grounding classifications.

Third, future studies could investigate hybrid threat modelling workflows in which classical approaches provide structured architecture-based analysis while LLM-based approaches provide additional threat discovery and contextual reasoning. Such workflows should be evaluated directly rather than inferred from the separate performance of individual approaches.

Fourth, future work could evaluate additional AI models, including locally deployed, domain-adapted, and cybersecurity-oriented models, under consistent experimental conditions. Repeated executions could also be used to examine output variability and the influence of model configuration and prompting.

Finally, future research could investigate human–AI collaborative threat modelling and automated methods for validating, classifying, and prioritizing generated findings. Such studies could examine whether human feedback and structured validation can improve coverage, precision, redundancy, and architectural support while maintaining traceability.

6.6 Final Remarks

This thesis provided a comparative empirical evaluation of OWASP Threat Dragon, Microsoft Threat Modeling Tool (TMT), GPT-5.6, Llama 3 8B via Ollama, and ThreMoLIA across three structured LLM-integrated system scenarios.

The results demonstrate that the evaluated approaches produce different threat modelling outputs and that raw finding volume alone is insufficient for comparing their performance. ThreMoLIA achieved the highest reference-threat recall at 70.41% and the highest F1-score at 52.67%, while GPT-5.6 achieved the highest primary-match precision at 47.71%. These results illustrate different trade-offs between threat coverage, precision, redundancy, and architectural evidence support rather than a universally superior approach.

The quantitative evidence-grounding assessment further showed that 329 of the 1,025 generated findings (32.10%) were Fully Grounded. GPT-5.6 achieved the highest full grounding rate at 74.59%, followed by Llama 3 8B via Ollama at 31.52%, ThreMoLIA at 31.10%, Microsoft TMT at 19.60%, and OWASP Threat Dragon at 3.25%. Evidence grounding is interpreted as a distinct architectural-evidence dimension and not as a substitute for reference-threat matching or precision.

Overall, the study supports the use of LLM-based threat modelling as a complementary source of threat discovery and contextual security analysis. Generated findings should be validated against the system architecture, security requirements, and defined evaluation criteria before informing security decisions. The conclusions remain bounded by the three evaluated scenarios, five approaches, 98-threat expert-vetted reference baseline, and the experimental configurations and evaluation procedures documented in this thesis.

References

- [1] O. Adamov, D. Fucci, F. V. Jedrzejewski, R. Britto, and N. Saini, “Validating threat modeling results with the help of vulnerable test applications,” in *2026 32nd International Conference on Telecommunications (ICT)*. IEEE, 2026, pp. 227–230. [Online]. Available: <https://arxiv.org/abs/2605.23695>
- [2] D. Agarwal, A. Fabbri, B. Risher, P. Laban, S. Joty, and C.-S. Wu, “Prompt leakage effect and mitigation strategies for multi-turn LLM applications,” in *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing: Industry Track*, F. Dernoncourt, D. Preotiu-Pietro, and A. Shimorina, Eds. Miami, Florida, US: Association for Computational Linguistics, Nov. 2024, pp. 1255–1275. [Online]. Available: <https://aclanthology.org/2024.emnlp-industry.94/>
- [3] H. Chang, E. Bao, X. Luo, and T. Yu, “Overcoming the retrieval barrier: Indirect prompt injection in the wild for LLM systems,” in *35th USENIX Security Symposium (USENIX Security 26)*. Baltimore, MD: USENIX Association, Aug. 2026. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity26/presentation/chang-hongyan>
- [4] S. Chen, J. Piet, C. Sitawarin, and D. Wagner, “StruQ: Defending against prompt injection with structured queries,” in *34th USENIX Security Symposium (USENIX Security 25)*. Seattle, WA, USA: USENIX Association, 2025. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity25/presentation/chen-sizhe>
- [5] B. C. Das, M. H. Amini, and Y. Wu, “Security and privacy challenges of large language models: A survey,” vol. 57, no. 6. [Online]. Available: <https://doi.org/10.1145/3712001>
- [6] M. Fasha, F. A. Rub, N. Matar, B. Sowan, M. Al Khaldy, and H. Barham, “Mitigating the OWASP top 10 for large language models applications using intelligent agents,” in *2024 2nd International Conference on Cyber Resilience (ICCR)*. IEEE, 2024, pp. 1–9. [Online]. Available: <https://doi.org/10.1109/ICCR61006.2024.10532874>
- [7] D. Granata and M. Rak, “Systematic analysis of automated threat modelling techniques: Comparison of open-source tools,” vol. 32, no. 1, pp. 125–161. [Online]. Available: <https://doi.org/10.1007/s11219-023-09634-4>
- [8] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, “Not what you’ve signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection,” in *Proceedings of the 16th*

- ACM Workshop on Artificial Intelligence and Security*, ser. AISec '23. Association for Computing Machinery, pp. 79–90. [Online]. Available: <https://doi.org/10.1145/3605764.3623985>
- [9] F. V. Jedrzejewski, O. Adamov, and D. Fucci, “Threat modeling for large language model-integrated applications (thremolia),” in *2025 ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, pp. 505–507.
- [10] F. V. Jedrzejewski, D. Fucci, and O. Adamov, “ThreMoLIA: Threat modeling of large language model-integrated applications,” in *Proceedings of the 29th International Conference on Evaluation and Assessment in Software Engineering*, ser. EASE '25. Association for Computing Machinery, pp. 834–839. [Online]. Available: <https://doi.org/10.1145/3756681.3757083>
- [11] R. Karanjai, Y. Lu, H. H. Madhavarao, L. Xu, and W. Shi, “Context contamination in LLM analysis of network security logs: Poison with passive prompt injection and mitigation evaluation,” in *35th USENIX Security Symposium (USENIX Security 26)*. Baltimore, MD: USENIX Association, Aug. 2026. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity26/presentation/karanjai>
- [12] Y. Kaya, A. Landerer, S. Pletinckx, M. Zimmermann, C. Kruegel, and G. Vigna, “When ai meets the web: Prompt injection risks in third-party ai chatbot plugins,” in *2026 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2026, pp. 4223–4242.
- [13] L. Mauri and E. Damiani, “Modeling threats to AI-ML systems using STRIDE,” vol. 22, no. 17, p. 6662. [Online]. Available: <https://www.mdpi.com/1424-8220/22/17/6662>
- [14] W. B. Mbaka and K. Tuma, “Less is more: usefulness of data flow diagrams and large language models for security threat validation,” vol. 31, no. 5, p. 122. [Online]. Available: <https://doi.org/10.1007/s10664-026-10837-z>
- [15] M. Mollaeefar, A. Bissoli, D. Van Landuyt, and S. Ranise, “PILLAR: LINDDUN privacy threat modeling using LLMs,” in *2025 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pp. 278–286.
- [16] T. R. Pathe and S. Hacks, “Towards threat modeling with large language models - automating domain-specific language creation in meta attack language (MAL),” in *Conceptual Modeling*, D. Bork, R. Lukyanenko, S. Sadiq, L. Belatreche, and O. Pastor, Eds. Springer Nature Switzerland, pp. 146–164.
- [17] R. Scandariato, K. Wuyts, and W. Joosen, “A descriptive study of microsoft’s threat modeling technique,” vol. 20, no. 2, pp. 163–180. [Online]. Available: <https://doi.org/10.1007/s00766-013-0195-2>
- [18] S. Schneider, N. E. D. Ferreyra, P.-J. Quéval, G. Simhandl, U. Zdun, and R. Scandariato, “How dataflow diagrams impact software security analysis: an empirical experiment,” in *2024 IEEE International Conference on Software Analysis, Evolution and Reengineering (SANER)*. IEEE, pp. 952–963. [Online]. Available: <https://ieeexplore.ieee.org/document/10589804/>

- [19] L. Sion, K. Yskout, D. Van Landuyt, and W. Joosen, “Solution-aware data flow diagrams for security threat modeling,” in *Proceedings of the 33rd Annual ACM Symposium on Applied Computing*, ser. SAC '18. Association for Computing Machinery, pp. 1425–1432. [Online]. Available: <https://doi.org/10.1145/3167132.3167285>
- [20] K. Tuma, D. Hosseini, K. Malamas, and R. Scandariato, “Inspection guidelines to identify security design flaws,” in *Proceedings of the 13th European Conference on Software Architecture - Volume 2*, ser. ECSA '19. Association for Computing Machinery, pp. 116–122. [Online]. Available: <https://doi.org/10.1145/3344948.3344995>
- [21] K. Tuma, C. Sandberg, U. Thorsson, M. Widman, T. Herpel, and R. Scandariato, “Finding security threats that matter: Two industrial case studies,” vol. 179, p. 111003. [Online]. Available: <https://linkinghub.elsevier.com/retrieve/pii/S016412122100100X>
- [22] K. Tuma and R. Scandariato, “Two architectural threat analysis techniques compared,” in *Software Architecture*, ser. Lecture Notes in Computer Science, C. E. Cuesta, D. Garlan, and J. Pérez, Eds., vol. 11048. Cham: Springer International Publishing, 2018, pp. 347–363. [Online]. Available: https://doi.org/10.1007/978-3-030-00761-4_23
- [23] K. Tuma, L. Sion, R. Scandariato, and K. Yskout, “Automating the early detection of security design flaws,” in *Proceedings of the 23rd ACM/IEEE International Conference on Model Driven Engineering Languages and Systems*, ser. MODELS '20. Association for Computing Machinery, pp. 332–342. [Online]. Available: <https://doi.org/10.1145/3365438.3410954>
- [24] D. Van Landuyt, M. Mollaeefar, M. Raciti, S. Verreydt, A. Kalash, A. Bissoli, D. Preuveneers, G. Bella, and S. Ranise, “A comparative benchmark study of LLM-based threat elicitation tools,” vol. 177, p. 108243. [Online]. Available: <https://linkinghub.elsevier.com/retrieve/pii/S0167739X25005370>
- [25] D. Van Landuyt and W. Joosen, “A descriptive study of assumptions in STRIDE security threat modeling,” vol. 21, no. 6, pp. 2311–2328. [Online]. Available: <https://doi.org/10.1007/s10270-021-00941-7>
- [26] Y. Yao, J. Duan, K. Xu, Y. Cai, Z. Sun, and Y. Zhang, “A survey on large language model (LLM) security and privacy: The good, the bad, and the ugly,” vol. 4, no. 2, p. 100211. [Online]. Available: <https://linkinghub.elsevier.com/retrieve/pii/S266729522400014X>

This appendix contains supplementary material supporting the methodology, experimental evaluation, and analysis presented in this thesis. Its purpose is to provide additional information required for reproducibility, verification of results, and transparency of the comparative threat modelling study.

The appendix presents the evaluated system scenarios, expert reference threat set, supplementary evaluation information, threat mappings, and additional experimental results that are not included in the main chapters because of space considerations.

A.1 Evaluated System Scenarios

Three LLM-integrated software system scenarios were used as the study objects for the comparative evaluation. Each scenario defines a specific system architecture together with the components, actors, interactions, data flows, trust boundaries, security requirements, assets, and assumptions required for threat modelling.

The same underlying scenario definitions were maintained across the evaluation. The representation and interaction procedure could differ according to the requirements of each evaluated approach, but the underlying system characteristics used as the basis for comparison remained fixed.

The three scenarios were:

1. LLM-Integrated Authentication System;
2. LLM-Integrated Secure File Management System; and
3. LLM-Integrated Account Recovery and Profile Management System.

The detailed scenario descriptions and their corresponding architectural representations are provided in the following subsections.

A.1.1 Scenario 1: LLM-Integrated Authentication System

Scenario 1 represents the LLM-Integrated Authentication System evaluated in this study. The scenario provides a structured architecture for analysing security threats associated with authentication-related functionality and the integration of LLM functionality.

The scenario definition specifies the system components, actors, interactions, data flows, trust boundaries, security requirements, and other architectural information used during threat modelling.

The corresponding expert reference threat set contains 32 reviewed reference threats. These threats form the Scenario 1 portion of the 98-threat expert reference baseline used for the comparative coverage analysis.

The complete architectural specifications and data flows for this scenario are documented in the system prompts provided in Appendix A.9.

A.1.2 Scenario 2: LLM-Integrated Secure File Management System

Scenario 2 represents the LLM-Integrated Secure File Management System evaluated in this study. The scenario focuses on secure file-management functionality and interactions involving users, files, document processing, access control, and the LLM-based assistant.

The scenario definition specifies the components, actors, data flows, trust boundaries, security requirements, assets, and other architectural relationships required for the threat modelling evaluation.

The corresponding expert reference threat set contains 33 reviewed reference threats. These threats form the Scenario 2 portion of the 98-threat expert reference baseline used for the comparative coverage analysis.

The complete architectural specifications and data flows for this scenario are documented in the system prompts provided in Appendix A.9.

A.1.3 Scenario 3: LLM-Integrated Account Recovery and Profile Management System

Scenario 3 represents the LLM-Integrated Account Recovery and Profile Management System evaluated in this study. The scenario focuses on account recovery, profile management, authentication-related interactions, and the integration of an LLM-based assistant.

The scenario definition specifies the components, actors, data flows, trust boundaries, security requirements, assets, and other architectural relationships required for the threat modelling evaluation.

The corresponding expert reference threat set contains 33 reviewed reference threats. These threats form the Scenario 3 portion of the 98-threat expert reference baseline used for the comparative coverage analysis.

The complete architectural specifications and data flows for this scenario are documented in the system prompts provided in Appendix A.9.

A.2 Expert Reference Threat Set

The expert-vetted reference threat set provides the comparison baseline used to evaluate the coverage of the generated threat findings. The final baseline contains 98 reviewed reference threats distributed across the three scenarios.

The reference threats were independently identified by security experts from Waibloz AB based on the corresponding scenario architectures. The resulting refer-

Table A.1: Distribution of Reference Threats Across Scenarios

Scenario	Reference Threats
Scenario 1	32
Scenario 2	33
Scenario 3	33
Total	98

ence threat set was subsequently used as the common comparison baseline for the five evaluated approaches.

The available research records retain the resulting reference threat set and its scenario-level distribution but do not retain sufficient methodological information to establish the exact number of participating experts, their individual qualifications, the complete pre-reconciliation threat lists produced by each expert, or a formal inter-expert agreement statistic. Accordingly, these details are not inferred or reconstructed in this study.

The expert-vetted reference threat set is therefore treated as a structured comparison baseline rather than as an exhaustive or absolute ground-truth representation of all possible security threats. A generated finding that does not correspond to a reference threat is not automatically invalid, because the reference set may not represent every possible security concern. Conversely, correspondence with a reference threat does not by itself establish complete correctness or architectural grounding.

The reference threat set is used consistently throughout the reference-threat coverage, precision, recall, and related comparative analyses presented in this thesis. Its role is to provide a common and consistently applied comparison baseline across the evaluated approaches rather than to establish the complete security properties of the analysed systems.

A.3 Threat Mapping Methodology

This section provides the detailed mapping rules used to compare generated threat findings against the expert reference threat set.

A generated finding was assessed against the corresponding reference threat using the defined mapping criteria. The assessment considered the following characteristics:

1. whether the finding described the same or a substantially equivalent security issue or attack mechanism;
2. whether the finding affected the same or an equivalent system component, architectural element, or data flow; and
3. whether the finding addressed the same or an equivalent security property.

The mapping assessment distinguished between different degrees of correspondence between generated findings and reference threats. Where applicable, findings could be characterized as:

- **Exact Match:** the generated finding corresponds directly to the reference threat with respect to the underlying security issue, relevant architectural element, and security property.
- **Partial Match:** the generated finding corresponds to the underlying security concern represented by the reference threat but differs in one or more aspects, such as attack mechanism, architectural specificity, or description.
- **Related Threat:** the generated finding represents a security concern related to a reference threat but does not satisfy the criteria required for a valid reference-threat match.
- **Unmatched Finding:** no sufficiently corresponding reference threat could be identified.

For the primary quantitative evaluation, reference-threat matching was performed using a one-to-one primary-match rule. Each reference threat could contribute at most one **Primary True Positive (Primary TP)** for each approach and scenario. When multiple generated findings corresponded to the same reference threat, only one finding was retained as the primary match; additional equivalent findings were classified as **Duplicates**.

A generated finding that did not correspond sufficiently to a reference threat was classified as a **False Positive (FP)**. A reference threat for which no valid primary generated finding was identified was classified as a **False Negative (FN)**. This procedure prevents multiple equivalent generated findings from artificially increasing reference-threat coverage.

Table A.2: Primary Threat-Mapping and Evaluation Categories

Category	Evaluation Treatment
Primary TP	One generated finding selected as the primary valid match for a reference threat.
Duplicate	Additional generated finding corresponding to a reference threat already matched by a Primary TP; does not increase recall.
FP	Generated finding without a sufficiently valid correspondence to the expert reference threat set.
FN	Reference threat without a valid Primary TP.

Reference-threat coverage was based on the number of distinct reference threats for which at least one valid Primary TP was identified. Duplicate findings therefore did not increase coverage or recall.

The mapping procedure was applied consistently across the evaluated threat sets. Original generated findings were retained separately from their mapping classifications to preserve traceability between the experimental outputs and the comparative analysis.

Candidate mappings were assessed against the corresponding reference threat description and available scenario evidence. Low-confidence mappings were subjected

to the documented adjudication procedure. The final adjudication review covered 27 low-confidence Primary TP cases, of which 20 were retained as Primary TP cases and 7 were changed to alternative reference-threat matches. No reviewed case was changed to a false positive, and the adjudication did not introduce new reference threats or modify the generated datasets.

No threat was introduced into the generated datasets solely to increase coverage. Similarly, a generated finding was not classified as a reference match solely because it used similar terminology; correspondence with the underlying security issue and the relevant scenario context was required.

A.4 Detailed Evaluation Tables

This section contains supplementary evaluation tables supporting the comparative analysis presented in the main thesis.

The supplementary evaluation information includes:

- raw threat-finding counts;
- normalized threat counts;
- reference-threat coverage;
- precision and related evaluation measures;
- duplicate and redundancy analysis;
- supporting STRIDE and LLM-specific security analyses; and
- cross-approach comparisons.

The raw threat outputs are retained separately from normalized and evaluated datasets. This distinction preserves the original experimental findings and ensures that subsequent analytical processing does not replace the primary experimental evidence.

A.5 Generated Threat Model Outputs

This section provides supplementary information concerning the threat modelling outputs generated by the five evaluated approaches:

- Microsoft Threat Modeling Tool (TMT);
- OWASP Threat Dragon;
- GPT-5.6;
- Llama 3 8B via Ollama; and
- ThreMoLIA.

The original generated outputs are retained separately from the processed analysis datasets. This separation maintains traceability between the experimental outputs, the subsequent classification and mapping activities, and the results reported in this thesis.

Supporting experimental artefacts are retained according to the data- availability and confidentiality conditions described in the thesis. Confidential or non-approved Waibloz AB materials are not included in public research artefacts.

A.6 Additional Evaluation Calculations

This section presents the calculations used to derive the primary evaluation measures reported in the thesis.

A.6.1 Threat Coverage

Reference-threat coverage was calculated as:

$$\text{Coverage} = \frac{\text{Distinct Reference Threats with a Valid Primary TP}}{\text{Total Reference Threats}} \times 100 \quad (\text{A.1})$$

A reference threat was considered identified when at least one generated finding satisfied the defined reference-matching criteria and was selected as the Primary TP for that reference threat. Additional equivalent findings were treated as duplicates and did not increase coverage.

A.6.2 Threat Recall

Because each reference threat could contribute at most one Primary TP, recall was calculated as:

$$\text{Recall} = \frac{\text{Primary TP}}{\text{Reference Threats}} \times 100 \quad (\text{A.2})$$

False negatives were calculated as:

$$\text{FN} = \text{Reference Threats} - \text{Primary TP} \quad (\text{A.3})$$

A.6.3 Threat Precision

Threat precision was calculated as:

$$\text{Precision} = \frac{\text{Primary TP}}{\text{Primary TP} + \text{FP}} \times 100 \quad (\text{A.4})$$

Duplicate findings were not counted as additional true positives and therefore did not increase precision or recall.

Precision is interpreted relative to the expert reference baseline and the defined mapping procedure. It is not treated as independent proof that a generated finding represents a confirmed real-world vulnerability.

A.6.4 F1-Score

The F1-score was calculated as the harmonic mean of precision and recall:

$$F1 = 2 \times \frac{\text{Precision} \times \text{Recall}}{\text{Precision} + \text{Recall}} \quad (\text{A.5})$$

A.6.4.1 Evidence Grounding

Evidence grounding was treated as a distinct analytical dimension from reference-threat matching. Grounding concerns whether a generated threat finding is supported by explicit evidence from the corresponding system architecture. The assessment framework distinguishes structural binding from semantic support: a finding should be connected to a specific architectural element or relationship, and the claimed attack mechanism and security consequence should be supported by that evidence.

The evidence-grounding assessment used the four predefined categories of Fully Grounded, Partially Grounded, Not Grounded, and Unassessable. A per-finding grounding coding assessment was performed for all 1,025 original generated findings using the preserved generated outputs and the corresponding scenario architectures.

The assessment resulted in 329 Fully Grounded findings (32.10%), 689 Partially Grounded findings (67.22%), 7 Not Grounded findings (0.68%), and no Unassessable findings. GPT-5.6 achieved the highest full grounding rate at 74.59, followed by Llama 3 8B executed through Ollama at 31.52 %, ThreMoLIA at 31.1%, Microsoft TMT at 19.60%, and OWASP Threat Dragon at 3.25%.

The grounding assessment was conducted as a single-pass coding analysis without an independent parallel assessor. The resulting classifications and rates should therefore be interpreted as descriptive measurements under the defined grounding rubric rather than as independently validated inter-rater measurements. Grounding is interpreted separately from precision, recall, and reference-threat coverage because architectural support does not by itself establish correspondence with the expert-vetted reference threat set.

A.7 Repository Structure

The project repository contains supporting materials used to document, analyse, and reproduce the experimental study, subject to applicable availability and confidentiality restrictions.

The available repository materials include, where applicable:

- scenario and architecture documentation;
- the expert reference threat set;
- original threat modelling outputs;
- structured evaluation datasets;
- analysis and calculation materials; and

- thesis documentation and supporting materials.

Experimental inputs, original generated outputs, processed datasets, and documentation are maintained as distinct artefact types where applicable. This organization supports traceability between the experimental procedure and the results reported in the thesis.

The availability of individual artefacts is subject to the data-availability, confidentiality, and repository arrangements described elsewhere in this thesis. Confidential or non-approved Waibloz AB materials are not included in public research artefacts.

A.8 Limitations and Additional Notes

This section provides additional methodological notes that complement the limitations discussed in the main thesis.

- **Analytical judgement:** Threat mapping and classification activities requiring analytical judgement were performed using the documented evaluation criteria and coding rules. Candidate mappings were assessed against the corresponding reference-threat descriptions and available scenario evidence. Low-confidence cases were subjected to the documented adjudication procedure.
- **Terminological differences:** Some generated findings required interpretation because the evaluated approaches use different terminology, levels of abstraction, and threat descriptions. Mapping decisions were therefore based on the underlying security concern and scenario context rather than textual similarity alone.
- **LLM variability:** LLM-generated outputs may vary between executions because of factors including model version, prompting, configuration, and execution conditions. Repeated executions were analysed where available, but consistency across repeated runs does not establish identical outputs for all future executions.
- **Architectural representation:** The evaluated approaches may represent or process architectural information differently. Such differences were retained as characteristics of the respective approaches rather than artificially modifying the original outputs.
- **Reference baseline:** The 98-threat expert reference baseline provides a structured comparison baseline but does not constitute exhaustive ground truth for every possible security threat in the analysed systems.

A.9 LLM Experimental Configuration and Prompts

This section documents the experimental configuration and prompts used for the LLM-based threat modelling approaches. The purpose of this section is to provide sufficient information to support reproducibility of the experimental procedure.

The LLM-based approaches evaluated in the study were ChatGPT, Ollama, and ThreMoLIA. For the ChatGPT and Ollama experiments, the same scenario-specific prompts were used for each corresponding scenario. Thus, Scenario 1 used the same prompt for ChatGPT and Ollama, Scenario 2 used the same prompt for ChatGPT and Ollama, and Scenario 3 used the same prompt for ChatGPT and Ollama. The model and execution environment were the variables that differed between these two approaches. The documentation distinguishes between model information, execution configuration, and the prompts used to generate the threat modelling outputs. Where a configuration parameter was not explicitly recorded, it is reported as “Not explicitly configured” rather than being reconstructed or assumed.

A.9.1 ChatGPT Configuration

ChatGPT was used as the cloud-based general-purpose LLM approach in the threat modelling experiments. The experimental model was GPT-5.6, accessed through the ChatGPT environment.

Table A.3: ChatGPT Experimental Configuration

Parameter	Recorded Value
Model identifier	GPT-5.6
Provider	OpenAI
Interface / runtime	ChatGPT
Deployment	Cloud-based
Model type	Large Language Model (LLM)
Analysis approach	STRIDE-based threat identification with OWASP LLM Top 10 mapping
Temperature	Not explicitly configured
Other generation parameters	Not explicitly configured

A.9.2 Ollama Configuration

Ollama was used as the local execution environment for the LLM-based threat modelling experiments. The model evaluated through this runtime was Llama 3 8B (llama3:8b).

A.9.3 Common Experimental Prompts for GPT-5.6 and Llama 3 8B via Ollama

The same scenario-specific prompts were used for GPT-5.6 and Llama 3 8B via Ollama. Thus, for each scenario, the prompt content and specified threat-modelling requirements were held constant across the two approaches, while the underlying language model and execution environment differed.

The prompts are reproduced verbatim from the experimental records. Formatting has been preserved where possible to maintain the documented experimental input.

Table A.4: Llama 3 8B Experimental Configuration via Ollama

Parameter	Recorded Value
Model name	Llama 3 8B
Model identifier	llama3:8b
Provider / developer	Meta
Runtime	Ollama
Deployment	Local / on-device
Model size	8.03 billion parameters
Quantization	Q4_0
Approximate model size on disk	4.7 GB
Context window	8K tokens
Analysis approach	STRIDE-based threat identification with OWASP LLM Top 10 mapping
Temperature	Not explicitly configured

A.9.3.1 Scenario 1: LLM-Integrated Authentication Assistant System

Scenario 1 Prompt

LLM-Integrated Authentication Assistant System

You are a cybersecurity threat modelling expert specializing in LLM-integrated systems. Perform a detailed threat modelling analysis for the following system.

The analysis must be based strictly on the provided architecture and data flows. Do not include components, data stores, or responsibilities that are not described.

System Name:

LLM-Integrated Authentication Assistant System

System Objective:

The system provides user authentication functionality with an AI chatbot assistant that answers questions with authentication-related questions and provides general account assistance. The AI chatbot component is only an assistance layer and must never perform authentication decisions, account management, credential verification, or account modifications.

Architecture Description:

Trust Boundary 1:

External User Environment (untrusted)

Entity:

EE1 End User

The user can:

- register an account
- submit login requests
- ask chatbot questions

All user inputs, including chatbot prompts, must be considered potentially malicious.

Application Environment (trusted application logic)

Process P1:

Web Frontend Interface

Responsibilities:

- receives user registration requests
- receives login requests
- receives chatbot questions

- displays responses

P1 does not authenticate users directly.

Process P2:

Authentication Service

Responsibilities:

- creates accounts
- verifies user credentials
- communicates with the user database
- performs authentication decisions

P2 is the only component responsible for authentication.

Process P3:

Session Management Module

Responsibilities:

- creates sessions after successful authentication
- manages session lifecycle
- stores and validates session information

Session tokens must not be exposed to the AI components.

Process P4:

AI Chatbot Component

Responsibilities:

- answers user questions
- provides authentication-related assistance
- retrieves approved documentation/context

Restrictions:

- cannot authenticate users
- cannot verify credentials
- cannot access password hashes
- cannot access session tokens
- cannot modify accounts

Process P5:

LLM Integration Service

Responsibilities:

- prepares prompts
- sends approved context to external LLM
- receives generated responses
- performs application-level response handling

Data Store DS1:

User Database

Contains:

- usernames
- salted password hash values
- account information
- authentication records

Plaintext passwords are not stored.

Data Store DS2:

Session Storage

Contains:

- session identifiers
- session metadata
- token-related information

Data Store DS3:

Knowledge Base / Context Repository

Contains:

- approved authentication documentation
- chatbot guidance information

Does not contain:

- passwords
- password hashes
- session tokens
- API keys

External Entity EE2:

External LLM Provider

Characteristics:

- third-party service
- outside application security control

Only sanitized prompts and authorization-approved context are sent.

No:

- passwords
- password hashes
- session tokens
- secrets

may cross this boundary.

Important Data Flow Assumptions:

1. Authentication decisions are performed only by P2.
2. Session lifecycle is controlled only by P3.
3. AI components cannot bypass authentication or authorisation.
4. External LLM output is considered untrusted.
5. User inputs and chatbot prompts may contain malicious instructions.

Threat Modelling Requirements:

Identify:

1. STRIDE-based threats
2. LLM-specific security threats
3. OWASP LLM Top 10 relevant threats
4. Threats related to trust boundaries
5. Threats related to:
 - prompt injection
 - sensitive information disclosure
 - insecure output handling
 - excessive agency
 - session security
 - authentication abuse
 - data leakage

For every threat provide:

- Threat ID

- Threat name
- STRIDE category
- Affected component/data flow
- Attack scenario
- Security impact
- Severity
- Likelihood
- Mitigation strategy
- Mapping to OWASP LLM Top 10 (if applicable)

Do not provide generic security advice. Every threat must be connected to this arch.

A.9.3.2 Scenario 2: LLM-Integrated Secure File Management System

Scenario 2 Prompt

LLM-Integrated Secure File Management System

You are a cybersecurity threat modelling expert.

Analyze the following LLM-integrated secure file management system.

Use only the provided architecture.

Do not assume additional components.

System Name:

LLM-Integrated Secure File Management System

System Objective:

The system allows users to upload, retrieve, and query files using an AI file assistant.

The AI assistant helps users understand documents but does not control file access.

Authorization decisions are always performed by the File Management Service.

Trust Boundary 1:

External User Environment (untrusted)

Entity:

EE1 End User

User can:

- upload files
- request file retrieval
- ask document-related questions

All user inputs, filenames, metadata, and questions are untrusted.

Process P1:

Web Frontend Interface

Responsibilities:

- accepts upload requests
- accepts retrieval requests
- sends user requests to backend services
- displays responses

Process P2:

File Management Service

Role:

Authorization Enforcement Point

Responsibilities:

- validates file access requests

- checks permissions
- controls file retrieval
- controls file storage operations

P2 is the only component allowed to decide whether a user can access a file.

Process P3:

AI File Assistant

Responsibilities:

- answers document-related questions
- assists users with document understanding

Restrictions:

- cannot access storage directly
- cannot make authorization decisions
- cannot bypass permission checks

It only receives authorization-approved document context.

Process P4:

LLM Integration Service

Responsibilities:

- creates sanitized prompts
- sends approved document context to external LLM
- receives generated responses

Data Store DS1:

Server Storage Repository

Contains:

- uploaded files
- document contents
- file metadata

Access is controlled by P2.

Data Store DS2:

User Permission Database

Contains:

- user identity
- file ownership
- access permissions

This is the authoritative authorization source.

External Entity EE2:

External LLM Provider

Outside application control.

Receives only:

- sanitized prompts
- authorization-approved context

Never receives:

- unauthorized files
- permission database contents
- private metadata

Important Security Assumptions:

1. P2 controls all file authorization.
2. AI cannot retrieve files independently.

3. AI receives only authorization-approved context.
4. LLM output is untrusted.
5. Uploaded files and user prompts may be malicious.

Analyze:

- STRIDE threats
- LLM-specific threats
- OWASP LLM Top 10 threats
- File security threats
- Authorization threats
- Data leakage threats

Focus especially on:

- prompt injection through documents
- malicious document content
- unauthorized file access
- broken access control
- excessive AI permissions
- sensitive document exposure
- insecure LLM context handling
- external provider risks

For every threat provide:

- Threat ID
- Threat name
- Category
- Affected component/data flow
- Attack description
- Impact
- Severity
- Likelihood
- Mitigation
- OWASP mapping

A.9.3.3 Scenario 3: LLM-Integrated Account Recovery and Profile Management System

Scenario 3 Prompt

LLM-Integrated Account Recovery and Profile Management System

You are a cybersecurity threat modelling expert.

Perform a detailed threat modelling analysis of the following LLM-integrated account profile management system.

Follow the architecture exactly.

Do not introduce components that are not described.

System Name:

LLM-Integrated Account Recovery and Profile Management System

System Objective:

The system allows users to recover accounts and update profiles.

The AI assistant provides guidance only.

The AI assistant cannot:

- authenticate users
- approve recovery
- generate recovery tokens
- validate recovery tokens
- modify profiles

Trust Boundary 1:

External User Environment

Entity:

EE1 End User

User can:

- request account recovery
- submit recovery information
- ask account-related questions

All user inputs are untrusted.

Process P1:

Web Frontend Interface

Responsibilities:

- receives recovery requests
- receives profile update requests
- communicates with backend services
- displays results

Process P2:

Account Recovery Service

Role:

Recovery Authorization Authority

Responsibilities:

- verifies identity
- validates recovery requests
- generates recovery tokens
- validates recovery tokens
- controls recovery authorization

P2 is the only component responsible for recovery decisions.

Process P3:

Profile Management Service

Responsibilities:

- performs profile updates
- updates account information only after authorized recovery approval

Process P4:

AI Account Support Assistant

Responsibilities:

- answers account-related questions
- provides recovery guidance

Restrictions:

Cannot:

- authenticate users
- authorize recovery
- create tokens

- validate tokens
- modify profiles

Process P5:

LLM Integration Service

Responsibilities:

- creates sanitized prompts
- sends approved context
- receives external LLM responses

Data Store DS1:

User Database

Contains:

- account identity
- profile information
- recovery verification information

Data Store DS2:

Recovery Token Storage

Contains:

- active recovery tokens
- token metadata
- expiration information
- token consumption/invalidation state

External Entity EE2:

External LLM Provider

Outside application security control.

Receives only:

- sanitized prompts
- authorization-approved context

Never receives:

- recovery tokens
- identity verification secrets
- private account data

Important Security Assumptions:

1. Recovery authorization is performed only by P2.
2. Token lifecycle is controlled only by P2 and DS2.
3. AI provides assistance only.
4. AI cannot influence recovery decisions.
5. External LLM output is untrusted.
6. User-provided recovery information may be malicious.

Analyze threats related to:

- account takeover
- recovery token abuse
- token replay
- token leakage
- identity verification bypass
- privilege escalation
- unauthorized profile modification
- prompt injection

- sensitive information disclosure
- insecure output handling
- excessive AI agency
- external LLM risks

For each threat provide:

- Threat ID
- Threat name
- STRIDE category
- Affected component/data flow
- Attack scenario
- Impact
- Severity
- Likelihood
- Mitigation
- OWASP LLM Top 10 mapping

Prompt identity across ChatGPT and Ollama. The same scenario-specific prompts reproduced above were used for both ChatGPT and Ollama. Thus, for each scenario, the prompt content and threat-modelling requirements were held constant across the two approaches, while the underlying language model and execution environment differed.

